



CÁTEDRA INCIBE
Digitalización y Ciberseguridad Hídrica



AGÈNCIA DE
**CIBERSEGURETAT
DE CATALUNYA**

Tendencias de Ciberseguridad en el Sector del Agua



Resumen ejecutivo

El sector del agua abarca actividades que incluyen la captación, el tratamiento, la distribución y el saneamiento del agua. Este sector es vital para el funcionamiento de la sociedad, la agricultura, la industria y el bienestar de la población, al ser el agua un recurso esencial. Para cumplir con estas funciones, se requiere una infraestructura robusta y eficiente, adaptada a las diversas demandas de consumo agrícola, industrial y doméstico, así como a las características geográficas y climáticas de cada región.

Con la digitalización y la conectividad a internet, el sector del agua ha mejorado su eficiencia y personalización de servicios, pero se enfrenta a nuevos desafíos de ciberseguridad. Las infraestructuras críticas, diseñadas originalmente para entornos cerrados, ahora son vulnerables a las amenazas digitales. Este informe analiza los riesgos más críticos en términos de disponibilidad, integridad y confidencialidad de la información, factores esenciales que impactan directamente en la ciudadanía.

El funcionamiento de la infraestructura del agua resulta esencial para garantizar el suministro a toda la población. Por ello, la disponibilidad de la información es vital para evitar desabastecimientos. Esta disponibilidad está afectada por factores como la criticidad del sistema y la falta de digitalización, y puede verse comprometida por ataques de grupos ciberdelinquentes o los llevados a cabo a través de programas maliciosos que restringen el acceso a información esencial.

La información gestionada por la infraestructura del agua es crucial para garantizar su calidad y potabilidad, especialmente en el suministro a la ciudadanía, que es cuando impacta directamente en la salud pública. La integridad de los datos afronta riesgos significativos debido a manipulaciones, las cuales pueden tener consecuencias catastróficas. Estos riesgos se agravan con el uso de tecnologías como el almacenamiento en la nube o la inteligencia artificial, que gestionan y emplean la información para la toma de decisiones.

El sector del agua tiene acceso a información personal de cada uno de los clientes, como nombres, direcciones y datos bancarios. Por ello, es esencial proteger estos datos contra robos. Las amenazas cibernéticas tradicionales, como la ingeniería social, ponen en riesgo la confidencialidad de dicha información. Los ataques exitosos pueden llevar a la suplantación de identidad, lo que afecta directamente a los clientes.

La evolución en digitalización de la infraestructura hídrica es necesaria y se está realizando de manera gradual, lo que supone la introducción de nuevos riesgos que pueden afectar la salud pública o los derechos de los ciudadanos. La heterogeneidad de la infraestructura y la tecnología operacional crean amenazas cibernéticas. Por este motivo, las entidades del sector deben abordar la seguridad en todas sus dimensiones, para protegerse de actores maliciosos con intereses económicos, políticos o disruptivos.



Índice

Resumen ejecutivo	2
1. Introducción	5
2. Las infraestructuras del ciclo del agua: consideraciones previas	6
2.1. Las entidades del ciclo del agua	7
2.2. Arquitectura IoT en el ciclo del agua	8
3. Introducción a los ciberataques a las entidades del sector del agua	10
3.1. Principales técnicas de ciberataques.....	10
3.2. Motivaciones tras los ciberataques y perfil de los agresores.....	11
3.3. Ataques a los tres pilares de la información	12
4. La amenaza de la indisponibilidad de información en el sector del agua y sus consecuencias	14
4.1. Un corte de servicio en el sector del agua tiene impacto económico, así como en la seguridad y el bienestar social	15
4.2. La creciente tensión geopolítica impulsa el aumento de ciberataques patrocinados por Estados rivales.....	17
4.3. El <i>hacktivismo</i> se mezcla con la agenda geopolítica y amenaza las infraestructuras críticas con ataques complejos y destructivos	19
4.4. El <i>ransomware</i> demuestra que puede poner en riesgo el operativo de la infraestructura hídrica.....	20
4.5. Los ataques DDoS suponen un riesgo para las comunicaciones del sector hídrico en espacios abiertos.....	23
4.6. Las regulaciones y estándares promueven y exigen sistemas digitales resilientes para la continuidad del sector del agua	24
4.7. Recomendaciones	26
5. La amenaza de sabotajes a la integridad de los datos en el sector y sus consecuencias....	27
5.1. El tratamiento del agua es objetivo potencial de ciberataques para impactar en la salud pública mediante la manipulación de sistemas	28
5.2. Los sistemas antiguos con conectividad plantean un auténtico desafío para la ciberseguridad del sector del agua	29
5.3. La integración de IA y de IoT optimiza la gestión del agua, pero introduce desafíos en la seguridad de los datos.....	31
5.4. La proliferación de bulos y la falta de veracidad de la información pública amenazan la estabilidad social y la salud pública.....	33
5.5. El compromiso de los proveedores de <i>software</i> , servicios remotos y plataformas de datos también es un vector de ataque.....	34



5.6. El acceso privilegiado de empleados internos amenaza la seguridad de los sistemas industriales del agua	35
5.7. Recomendaciones	37
6. La amenaza a la confidencialidad de los datos en el sector del agua crece con la digitalización y su valor estratégico.....	38
6.1. La filtración de datos personales en el sector puede facilitar el fraude y el robo de identidad de sus clientes.....	39
6.2. Los consumidores están expuestos a ataques de suplantación de las entidades de suministro de agua con <i>phishings</i> y falsos técnicos	41
6.3. También en el sector del agua, el <i>phishing</i> supone una auténtica amenaza a la seguridad y confidencialidad de los datos	42
6.4. El enfrentamiento económico y estratégico entre países rivales incentiva el ciberespionaje industrial en el sector del agua.....	43
6.5. <i>Ransomware</i> con doble extorsión: afecta la disponibilidad de un servicio esencial y el robo de los datos personales de clientes	44
6.6. Hace falta una cultura de actualizaciones y análisis de vulnerabilidades para proteger la información	46
6.7. El marco regulador impone medidas estrictas para proteger los datos personales de los usuarios.....	47
6.8. Recomendaciones	48



1.Introducción

El agua es un recurso imprescindible para la supervivencia humana y con una incidencia crítica en la salud pública, de cuya gestión se responsabiliza un sector especializado que genera una multitud de datos y tiene un impacto económico significativo. La casuística de la infraestructura en la que se basa el sector del agua es singular, debido a los diferentes factores que la configuran, como la ubicación geográfica de los recursos hídricos, los sistemas y plantas utilizados para su tratamiento, la distribución de los puntos de consumo o las tecnologías usadas.

Además, dicho sector está experimentando una progresiva y profunda digitalización, lo que lo expone a nuevas y complejas amenazas. Si no se gestionan adecuadamente, existe el riesgo de que puedan derivar en situaciones críticas que comprometan la eficiencia del sector e, incluso, el bienestar de la población. Por ejemplo, un caso muy sonado fue el incidente de Queensland en el año 2000, en el que se comprometió la calidad del agua, o el incidente de Oldsmar, en Florida, en 2021, donde un intento de ciberataque puso en riesgo la potabilidad del agua.

Con el fin de proteger los datos y los sistemas de información utilizados en este sector, y, por consecuencia, proteger el correcto suministro del agua y la salud pública, las entidades involucradas deben afrontar el análisis de las ciberamenazas que puedan afectarlas. Para ello, en el presente documento se propone abordar un estudio de las principales amenazas, clasificándolas según las dimensiones de la información: disponibilidad, integridad y confidencialidad. El origen de estas amenazas es variado: grupos de APT, amenazas internas, actores de amenazas del *ransomware*, *hacktivistas*, etc. Pero todos ellos constituyen actores de amenazas que buscan interrumpir los sistemas de información para el suministro, alterar datos cruciales o robar información confidencial.

Este informe trata, de modo ordenado y efectivo, las principales tendencias con relación a las amenazas cibernéticas que acechan el sector del agua, pero también las medidas de seguridad pertinentes que permiten aumentar el nivel de protección frente a potenciales actos maliciosos.

2. Las infraestructuras del ciclo del agua: consideraciones previas

El concepto “infraestructuras del ciclo del agua” se refiere a toda obra pública destinada al transporte y gestión del agua, de modo que suele incluir redes de conductos y tuberías, plantas de tratamiento y todos los elementos tecnológicos asociados. La infraestructura del ciclo del agua es muy heterogénea y depende tanto de la distribución de los recursos hídricos como del consumo de dichos recursos en el territorio.

Los recursos hídricos están conformados por las masas de agua dulce en todo el territorio nacional y en multitud de formas superficiales (como lagos, ríos, embalses) y subterráneos (como acuíferos). En cuanto a su consumo, este se puede clasificar en tres tipos, y cada uno requiere calidades del agua distintas:

- Consumo agrícola y del sector primario: requiere poca calidad, destinado a riego de cultivos.
- Consumo industrial y del sector secundario: requiere un rango muy variable de calidad según el producto generado.
- Consumo doméstico o urbano y del sector terciario: requiere alta calidad (agua potable), destinado a viviendas y establecimientos.

Como norma general, el consumo agrícola de recursos hídricos es generalizado en superficies extensas y se nutre de infraestructuras sencillas y descentralizadas. No obstante, el sector agrícola tiene una importancia estratégica clave en España: supone aproximadamente un 80 % del consumo de recursos hídricos.¹ A su vez, el conjunto del sector agroalimentario supuso un 16,4 % de la producción y un 15,1 % del empleo generado en 2021.²

Tanto el consumo urbano como el industrial requieren infraestructuras más complejas para suministrar agua potable o con determinadas especificaciones en cuanto a calidad. Ambos consumos necesitan la infraestructura completa del ciclo urbano del agua, la cual asume una gran responsabilidad por su impacto en la vida y las actividades humanas. Dicho ciclo está compuesto de las etapas siguientes:

1. Captación. Recolección de los recursos hídricos a partir de masas de agua dulce superficiales (ríos, lagos o embalses) y/o subterráneas (acuíferos).
2. Potabilización. Una vez captada, el agua se somete a tratamiento en las plantas de potabilización.
3. Distribución de agua potable. El agua tratada es distribuida a través de una red de tuberías hasta hogares, industrias, negocios y otras infraestructuras.
4. Recolección de aguas residuales. Después de su uso, el agua queda contaminada de materia orgánica y productos químicos; esto es lo que se conoce como “aguas

¹ RTVE, “La agricultura, el «elefante en la habitación» que consume el 80 % del agua en la España de las sequías”, 2024, <https://www.rtve.es/noticias/20240217/agricultura-consume-80-agua-espana-sequias/15972242.shtml>.

² Cámara de Comercio España, “El sector agroalimentario genera 16 de cada 100 euros producidos por la economía española”, 2024, <https://www.camara.es/sector-agroalimentario-genera-16-100-euros-producidos-economia-espanola>.

residuales”. Dichas aguas son recolectadas a través de redes de alcantarillado que las transportan hacia estaciones de tratamiento.

5. Tratamiento de aguas residuales. Las aguas residuales se someten a procesos de depuración o tratamiento para eliminar contaminantes antes de ser devueltas al ambiente o reutilizadas.
6. Reutilización del agua tratada. Después del tratamiento, en lugar de ser vertida en el medio, el agua depurada puede ser reutilizada para distintos fines agrícolas, industriales, urbanos u otros.

2.1. Las entidades del ciclo del agua

El sector profesional del agua puede clasificarse en función del tipo de entidades del ciclo del agua al que pertenece:

1. **Administración hidráulica.** Son responsables de la gestión, supervisión y licitación de servicios relativos al dominio público hidráulico. Bajo su titularidad recaen todas las infraestructuras del ciclo del agua de la red de agua potable (a excepción de las de uso industrial y privado).

Según su ámbito territorial (nivel de centralización), las entidades pueden ser:

- 1.1. Entidades centrales de la administración hidráulica: organismos de cuenca y agencias territoriales.
- 1.2. Entidades locales y agrupaciones: estos entes gestionan por delegación las responsabilidades de la administración hidráulica correspondiente, pero, adicionalmente, deben comunicarse con esta, como supervisora indirecta de las actuaciones.

Su adopción de la digitalización es mediana, y se basa fundamentalmente en:

- a. Plataformas web de registro de informes analíticos, auditorías e incidencias. Dichas plataformas permiten la comunicación con varias entidades simultáneamente.
 - b. Si supervisan directamente la explotación de infraestructura licitada, pueden tener acceso a bases de datos que integran información de SCADA y resultados de laboratorio.
2. **Empresas gestoras de servicios de agua urbana** (generalmente de carácter privado). Su nivel de digitalización es relativamente elevado, principalmente por su potencial para optimizar recursos económicos y personales. Cabe destacar que tienden a buscar enfoques de gestión integrada de la digitalización, a través de plataformas BI (*business intelligence*). Estas plataformas permiten la gestión integrada de todas las actividades que realizan en todas las etapas del ciclo del agua en todos los ámbitos territoriales, y se fundamentan en plataformas web, el uso de bases de datos y servicios en la nube, tanto para almacenamiento de datos como para *software* de propiedad o comercial. Dicho esto, el nivel de digitalización de las empresas gestoras de agua urbana depende de su tamaño.

2.2. Arquitectura IoT en el ciclo del agua

La arquitectura IoT se basa en clasificar todos los dispositivos físicos (*hardware*) y digitales (*software*) de la cadena de valor en diferentes capas y en detallar sus interacciones, incluso si son entre capas distintas o con usuarios y dispositivos externos. Las capas de la arquitectura IoT son:

- a. Capa de percepción o capa de objetos: reúne todos los dispositivos físicos con capacidad de generar una señal a partir de un cambio en el entorno físico (sensores), mecanismos que alteran el funcionamiento de un proceso (actuadores) y sistemas de automatización varios (tales como los controladores lógicos programables o PLC, del inglés *programmable logic controllers*).
- b. Capa de red o capa de transporte: esta capa incluye todas las transmisiones de datos de los dispositivos de la capa de percepción hacia las otras capas. Es el conjunto de redes de comunicaciones de toda la cadena de valor.
- c. Capa de procesamiento: consiste en todos los procesos de cálculo y análisis ejercidos sobre los datos transmitidos desde la capa de percepción y a través de la capa de red. Existen distintos ejemplos según el grado de centralización de estos procesos: pueden darse de forma descentralizada, a través de *software* SCADA (*supervisory control and data acquisition*) o similar, integrado en dispositivos menores *in situ* donde se efectúan los procesos (lo que facilita el ciclo de transmisión de datos); o también pueden darse de forma centralizada, a través de bases de datos que acumulan los datos enviados y posteriormente interactúan con programas especializados.
- d. Capa de aplicaciones: reúne la inmensa mayoría de programas (*software*) destinados a la gestión de datos, y en especial aquellos diseñados para facilitar la interacción de los supervisores de la cadena de valor con cada parte de esta.
- e. Capa de negocios: esta capa consta de aquellos programas (*software*) destinados a la interacción con clientes de la cadena de valor. Así, consiste en aquellas aplicaciones que gestionan intercambios monetarios por bienes y servicios al final de la cadena, generalmente con usuarios con un perfil no experto o con un nivel de conocimientos inferior al de los usuarios de perfil experto que interactúan en la capa de aplicaciones y que actúan como supervisores de la cadena de valor.

A continuación, se presenta la clasificación y una breve descripción de los dispositivos y programas frecuentemente usados en el contexto de la arquitectura IoT de las infraestructuras del agua:



Capa de negocios

- Interfaz de usuario, adaptada al perfil del destinatario (puede ser tanto ciudadanía, otras empresas o incluso entidades gubernamentales y de la administración pública).
- Sistema de transacciones financieras.

Capa de aplicaciones

- Interfaz de usuario, sistema de monitoreo y consulta de bases de datos: posibilita la supervisión del sistema y la interacción con agentes expertos.
- *Software* GIS, analítica de datos, IA: posibilita extraer valor de la información generada.

Capa de procesamiento

- Bases de datos: acumulan toda la información en formatos homogéneos, realizan operaciones estadísticas y posibilitan el uso de aplicaciones más refinadas.
- SCADA (*supervisory control and data acquisition*): son sistemas para el control, monitoreo y análisis de dispositivos y procesos industriales.
- *Edge computing*: consiste en el uso de técnicas de almacenamiento y procesamiento de datos siguiendo un modelo distribuido a las fuentes de datos.

Capa de red

- Protocolos de comunicación: el conjunto de instrucciones dadas a los dispositivos para recabar y transmitir información, basado generalmente en el uso de internet y/o redes inalámbricas.

Capa de objetos

- Sondas: todos aquellos dispositivos que detectan un cambio en el entorno físico y lo registran mediante una señal eléctrica o mecánica.
- Actuadores: todos aquellos dispositivos que modifican las condiciones de operación de un proceso.
- PLC (*programmable logic controller*): permite la automatización de procesos industriales, conectando sondas y actuadores mediante un circuito de control lógico.

3. Introducción a los ciberataques a las entidades del sector del agua

Tal y como se ha descrito en las secciones anteriores, la infraestructura y los servicios del sector del agua se extienden a lo largo del país y mantienen una estrecha relación con una diversidad de actividades en la vida humana. Un ciberataque contra dicho sector puede conllevar consecuencias muy importantes, que afectarían no solo la disponibilidad y calidad del agua, sino también la salud pública, la economía y la estabilidad social. Por ello, las entidades del sector deben protegerse en sus dos ámbitos de actividad principales: el agua potable y las aguas residuales. Es en este último ámbito donde existe un mayor nivel de digitalización, pero la tendencia es al alza en ambos sectores.

ASPECTO	AGUA POTABLE	AGUAS RESIDUALES
Grado de digitalización	Medio-alto	Alto – muy alto
Control	PLC SCADA GIS Control remoto	PLC SCADA Control remoto
Tendencias digitales	Aumento de control y transparencia Simulación y optimización en tiempo real Análisis predictivo de calidad Optimización de la calidad del agua	Simulación y optimización en tiempo real Análisis predictivo de calidad Análisis predictivo de incidencias Análisis predictivo de consumos (reutilización)

3.1. Principales técnicas de ciberataques

Las entidades del ciclo del agua pueden verse afectadas por ciberataques muy variados, mediante técnicas diversas y dirigidos a diferentes fases del ciclo del agua, y cada tipología de ataque busca su objetivo.

En las siguientes secciones del informe se detallan las ciberamenazas a la disponibilidad, a la integridad de los datos y a su confidencialidad. Sin embargo, estas amenazas cibernéticas se pueden ilustrar con los siguientes ejemplos principales:

- Interrupción de la prestación del servicio y del suministro del agua mediante ataques de *distributed denial-of-service* (DDoS), *malware*, explotación de vulnerabilidades existentes, etc. Un caso particular son los ataques de



ransomware, que además comportan la posterior exigencia de rescate de los atacantes para liberar los archivos capturados.

- Alteración de la calidad del agua a través de ciberataques dirigidos a los programas de monitorización de la calidad del agua y a los que controlan la dosificación de productos añadidos, así como a los sensores de caudal y a los mecanismos de detección de fugas u otras incidencias.
- Estafas de grandes cantidades económicas, como, por ejemplo, el fraude del CEO o BEC (*business email compromise*), con el que suplantando directivos o proveedores para inducir a las víctimas a realizar transferencias financieras en beneficio del atacante.
- Robos masivos de datos de los usuarios y/o de negocio de la propia entidad a través de ataques de ingeniería social, como el *phishing*, la explotación de vulnerabilidades o el robo de credenciales de acceso.

3.2. Motivaciones tras los ciberataques y perfil de los agresores

Las motivaciones de los actores de amenazas que pretenden realizar ciberataques contra las entidades del sector del agua son variadas, pero se pueden dividir en dos grandes grupos:

- Motivación económica: el ciberataque proporciona beneficios económicos a los autores. En este apartado se incluyen:
 - Espionaje industrial: ciberataque a otras entidades para menoscabar su predominancia en el sector, a favor de otra u otras.
 - Ciberfraude: desvío de sumas económicas a través de engaños, a veces con esquemas complejos, dirigidos a los empleados de las entidades o a los consumidores.
 - Extorsión: desplegando un *ransomware*, se exige un pago para recuperar los datos encriptados; o bien, después de robar datos confidenciales, se amenaza con hacerlos públicos si no se abona un rescate (o incluso se venden en el mercado negro).
- Motivación ideológica o política: el ciberataque tiene un objetivo ideológico o político a nivel individual o colectivo. En este apartado se incluyen:
 - *Hacktivismo*: ataques a las infraestructuras del ciclo del agua que persiguen, mayoritariamente, reivindicar ideologías políticas o económicas e, incluso, exponer prácticas inadecuadas de la entidad afectada.
 - Ciberterrorismo: individuos o grupos no estatales dirigen sus ciberataques al ciclo del agua, un pilar de la salud pública, con objetivos políticos, ideológicos o religiosos, tratando de ejercer cierta influencia, generar miedo o desestabilizar a la sociedad rival.
 - Ciberguerra: Estados o actores respaldados por Estados, con el objetivo de infligir daño, u obtener ventaja estratégica o coercitiva frente a otros países, llevan a cabo acciones de ciberespionaje o la destrucción de

sistemas para interrumpir el suministro de agua y, así, debilitar al enemigo.

Detrás de los ciberataques contra las entidades del agua puede haber personas que actúan de forma individual, que forman parte de una red o un colectivo organizado, o que pertenecen a una organización con vínculos gubernamentales.

A su vez, los actores de amenazas responsables de los ciberataques pueden clasificarse en los siguientes grandes grupos:

- **Actores-Estado:** muy vinculados al espionaje industrial, ciberterrorismo y ciberguerra. Estos actores están respaldados por gobiernos y tienen como objetivo robar información confidencial o interrumpir el correcto funcionamiento de los servicios esenciales de otros países. Están altamente financiados y actúan desde geografías donde están protegidos de otras jurisdicciones, lo que los hace complejos y difíciles de detectar.
- **Cibercriminales:** enfocados hacia el ciberfraude, la extorsión y el robo de información financiera o personal. Estos actores cometen delitos cibernéticos principalmente para obtener beneficios económicos. Su objetivo es maximizar sus ganancias a través de actividades ilícitas en línea y hacerlo sin alertar a las fuerzas policiales, para evitar que impulsen operaciones internacionales.
- **Hacktivistas:** obviamente, relacionados con el *hacktivismo* y, en algunos casos, con el ciberterrorismo. Utilizan técnicas de *hacking* o ataques DDoS para promover agendas políticas o sociales. Los *hacktivistas* creen que están provocando un cambio social positivo y se sienten justificados al atacar a individuos, organizaciones o agencias gubernamentales con el fin de revelar secretos u otra información delicada.
- **Mercenarios o PSOA (*private sector offensive actors*):** relacionados con el espionaje industrial, la extorsión y el ciberfraude. Son individuos o grupos contratados por organizaciones privadas para llevar a cabo ciberataques específicos. Su motivación principal es el beneficio económico o estratégico para sus contratantes, y operan con un alto grado de profesionalismo y discreción.

3.3. Ataques a los tres pilares de la información

Para comprender el impacto de los ciberataques, es indispensable conocer los tres pilares fundamentales de la información que dichos ciberataques buscan afectar y que la ciberseguridad se esfuerza por proteger: disponibilidad, integridad y confidencialidad. Cada pilar aborda un aspecto específico de la protección de la información.

1. **Disponibilidad:** garantiza que los sistemas y datos sean accesibles cuando se necesitan, protegiendo la infraestructura contra interrupciones que puedan impedir el acceso a la información o a los servicios.
2. **Integridad:** garantiza que los datos y sistemas sean precisos y no hayan sido alterados de manera no autorizada. Esto nos asegura que la información se mantenga completa.



3. **Confidencialidad:** protege la información restringida, así como la privacidad de los datos personales, con el fin de asegurar que solo las personas o sistemas autorizados puedan acceder a ella.

En las próximas secciones, se abordarán las amenazas cibernéticas dirigidas a los pilares de la información y a los sistemas de información (disponibilidad, integridad y confidencialidad) en el sector del agua. Comprender estas amenazas es esencial para protegerse y anticiparse a ellas, lo que resulta fundamental para mitigar o evitar el impacto de un incidente cibernético provocado por un ciberataque. De este modo, se asegura la continuidad y confiabilidad de los sistemas que dependen de dicha información.

4. La amenaza de la indisponibilidad de información en el sector del agua y sus consecuencias

En este punto del informe, ya se ha evidenciado que los sistemas de la información son un elemento clave en el sector hídrico. De hecho, gracias al correcto funcionamiento de estos sistemas se consigue que el suministro de agua llegue a los sectores primario (consumo agrícola), secundario (consumo industrial) y terciario (consumo doméstico o urbano). En este sentido, es oportuno recordar que la necesidad de disponer de agua es especialmente relevante en el sector primario, donde se consume el 80 % de los recursos hídricos estatales.³

Para asegurar que el suministro de agua sea continuo para todos estos sectores, es fundamental que los sistemas de información estén disponibles y operativos durante todas las fases del ciclo de vida del agua: captación, potabilización, distribución de agua potable, recolección de agua potable, recolección de aguas residuales, tratamiento de aguas residuales y reutilización de aguas tratadas. De hecho, al tratarse de un ciclo continuado, una interrupción en el funcionamiento de los sistemas de información en cualquiera de estas fases del ciclo tendría una afectación directa en las actividades posteriores.

El funcionamiento ininterrumpido de los sistemas de información, además de ser un elemento clave en el ciclo del agua, es necesario para garantizar una respuesta eficaz de la infraestructura del agua en situaciones de emergencia. Es el caso, por ejemplo, de la prevención de inundaciones derivadas de precipitaciones intensas. Un claro ejemplo de ello es el llamado “Azud del Repartiment”,⁴ una infraestructura hidráulica situada en el río Turia que, construida después de la devastadora inundación de 1957, tiene el propósito de desviar el caudal del río hacia el nuevo cauce, capaz de soportar 5000 m³/s,⁵ para evitar futuras inundaciones. Precisamente, en noviembre de 2024, durante la dana (depresión aislada en niveles altos) que afectó a Valencia, muchos expertos⁶ estuvieron de acuerdo en que dicha infraestructura actuó como una barrera, y evitó la inundación en la capital valenciana.

Dado que los sistemas de información en el sector hídrico son elementos críticos, existe un amplio número de regulaciones y estándares que versan sobre las medidas de seguridad necesarias para su protección frente a las amenazas cibernéticas. En el caso de España, las legislaciones más relevantes en este ámbito son la Ley de Protección de

³ RTVE, “La agricultura, el «elefante en la habitación» que consume el 80 % del agua en la España de las sequías”, 2024, <https://www.rtve.es/noticias/20240217/agricultura-consume-80-agua-espana-sequias/15972242.shtml>.

⁴ Parc del Túria, “Azud del Repartiment”, 2024, <https://parcdelturia.es/actividades/azud-del-repartiment/>.

⁵ Laboratorio de Hidráulica y Obras Hidráulicas, “Análisis y diagnóstico de la situación actual del nuevo cauce del río Turia y de la solución propuesta de supresión del azud intermedio”, 2024, https://hidraulc.webs.upv.es/w_turia.html.

⁶ Maldito Clima, “¿La DANA habría inundado Valencia si el cauce del Turia no se hubiera modificado con Franco?”, 2024, <https://maldita.es/clima/20241211/franco-desvio-turia-plan-sur-1957-salvar-vidas/>.

Infraestructuras Críticas, la trasposición de la Directiva NIS2 y el Esquema Nacional de Seguridad.

Habitualmente, las medidas de seguridad se establecen a nivel lógico, es decir, en los elementos presentes en las capas de aplicación, red o procesamiento mencionadas con anterioridad. Sin embargo, dadas las características particulares de la infraestructura del sector del agua, en el que diferentes elementos y dispositivos se distribuyen en espacios abiertos (como por ejemplo los sensores instalados en el transcurso de un río, en una presa, una depuradora, etc.), también hay que tener en cuenta la vertiente de la seguridad física para aquellos elementos de campo susceptibles de ser atacados tanto en el plano lógico como físico.

Aspectos a tratar:

- ✓ **Un corte de servicio en el sector del agua tiene un importante impacto económico, así como en la seguridad y el bienestar social.**
- ✓ **La creciente tensión geopolítica ocasiona el incremento de ciberataques patrocinados por Estados rivales.**
- ✓ **El *hacktivismo* evoluciona hacia una amenaza más compleja de las infraestructuras críticas.**
- ✓ **El *ransomware* pone en riesgo la disponibilidad de la infraestructura esencial del agua.**
- ✓ **Los ataques DDoS suponen un riesgo para las comunicaciones y los sistemas del sector hídrico.**
- ✓ **Las regulaciones y estándares promueven la continuidad del sector hídrico.**

4.1. Un corte de servicio en el sector del agua tiene impacto económico, así como en la seguridad y el bienestar social

Una interrupción en la infraestructura del sector hídrico no solo representa un grave riesgo para la salud pública y la seguridad y el bienestar general, sino que también puede desencadenar serias repercusiones en la actividad social y económica.

Este impacto negativo se ha podido comprobar en diferentes catástrofes naturales. Tal es el caso del huracán Katrina, en Nueva Orleans (Estados Unidos), en 2005: las bombas de agua utilizadas para eliminar el exceso de agua y evitar inundaciones en la ciudad fallaron. Dicho fallo fue resultado de dos factores principales: la gran cantidad de agua traída por el huracán y la pérdida de energía eléctrica debido a la caída del tendido eléctrico. Las bombas no pudieron drenar el agua de forma efectiva, lo que agravó la

inundación y aumentó los efectos negativos del huracán. Del mismo modo, en 2011, el tsunami que siguió al terremoto de Tohoku dañó el sistema de suministro eléctrico de la planta nuclear de Fukushima. Sin electricidad, las bombas de agua fallaron, lo que impidió el bombeo de agua de mar, necesario para enfriar los reactores nucleares, cuyo sobrecalentamiento, a su vez, generó una emergencia nuclear de gran magnitud.

Pero no solo las catástrofes naturales pueden provocar un corte en el suministro del agua: un ciberataque puede conllevar consecuencias igualmente devastadoras. Precisamente, la Oficina del Inspector General de la Agencia de Protección Ambiental de Estados Unidos ha identificado preocupaciones relativas a la ciberseguridad en los sistemas de agua potable, y ha señalado debilidades en la coordinación y respuesta a incidentes potenciales.⁷

También hay que hablar de los costes económicos. Un corte en la actividad del sector hídrico causado por un incidente cibernético supondrá pérdidas económicas importantes, tanto causadas por la suspensión de la propia actividad como por los costes de recuperación. Pero, indirectamente, también implicará pérdidas económicas en los sectores que necesitan el agua para llevar a cabo su actividad económica. Es el caso de la industria, la agricultura, así como también sectores de servicio como la restauración y la hostelería.

Para ilustrar la magnitud de las pérdidas económicas generales provocadas por la interrupción del suministro del agua, la EPA (Environmental Protection Agency) estadounidense plantea dos ejemplos hipotéticos de lo que podría suceder en el caso de una interrupción de la disponibilidad de suministro de agua:⁸

- Primer ejemplo: la compañía Charlotte Water, que atiende a más de 890 000 personas en Carolina del Norte, podría enfrentarse a una pérdida de ingresos diarios de unos 132 millones de dólares, lo que afectaría no solo a la compañía, sino también a los sectores que dependen de su suministro.
- Segundo ejemplo: el Proyecto Estatal de Agua de California, una infraestructura gestionada por el Estado que recolecta y distribuye agua a más de 27 millones de personas, podría sufrir pérdidas de hasta 61 000 millones de dólares por día ante una interrupción estatal del servicio.

Con relación al coste económico de recuperación de un incidente cibernético, este incluye la contratación de recursos externos para la investigación y recuperación del incidente, así como el equipamiento necesario. En este sentido, la ciudad de Jersey (Estados Unidos), después de ser víctima de un *ransomware* que impidió el acceso a información vital relacionada con el abastecimiento y el tratamiento de agua, estimó unas pérdidas económicas de 500 000 dólares en concepto de recuperación. Y eso sin sumarle pago de rescate alguno.

⁷ Infobae, “La Agencia de Protección Ambiental de Estados Unidos advirtió sobre el riesgo de la infraestructura por ciberataques”, 2024, <https://www.infobae.com/estados-unidos/2024/06/27/la-agencia-de-proteccion-ambiental-de-estados-unidos-advirtio-sobre-el-riesgo-de-la-infraestructura-por-ciberataques/>.

⁸ EPA, “Management Implication Report: Cybersecurity Related to Drinking Water Systems”, 2024, https://www.epa.gov/sites/default/files/reports/2024-11/full_report_-_25-n-0004t_1.pdf.

Por otro lado, hay que tener en cuenta que el importe medio del rescate pagado para recuperar los datos secuestrados por un *ransomware* superó los 2 500 000 dólares en 2024.⁹ El hecho de que algunas víctimas paguen estas cantidades astronómicas se debe a la capacidad de los ataques de *ransomware* de afectar servicios esenciales, como las entidades del sector del agua, las cuales no pueden hacer frente a largos periodos sin actividad y se ven forzadas a considerar el pago del rescate.

4.2. La creciente tensión geopolítica impulsa el aumento de ciberataques patrocinados por Estados rivales

El aumento de la tensión y los crecientes conflictos internacionales (como la actividad bélica de Rusia en Ucrania, o de Israel en el Próximo Oriente) han intensificado la polarización en las relaciones entre países y la creación de alianzas con intereses afines. En este contexto, el sector del agua, juntamente con otros servicios esenciales, gana gran relevancia dado que se erige en un objetivo potencial de ciberataques con motivación geopolítica.

Estos ataques cibernéticos buscan obtener información confidencial que proporcione una ventaja estratégica o política sobre el adversario, o bien dañar el funcionamiento de un servicio esencial para sembrar el caos y debilitar la confianza de la población rival. Un ejemplo claro de ello es Ucrania, que se enfrenta a una intensa actividad cibernética como resultado de su conflicto con Rusia; del mismo modo, la situación bélica entre Israel y Hamás también se ve reflejada en el ámbito cibernético. Si bien se trata de conflictos distintos, los patrones de actuación en el ciberespacio son similares.

Los principales responsables de dichos ciberataques son los actores de amenazas patrocinados por Estados, conocidos como grupos de APT (*advanced persistent threat*).

¿Qué es una APT?

Ataque a gran escala, subrepticio, sofisticado, continuo y dirigido contra una entidad específica. (Fuente: Termcat)

Un ejemplo de APT es Sandworm, también conocido como APT44, vinculado al ejército ruso y crucial en las campañas cibernéticas contra Ucrania. Pero su amenaza se extiende más allá, y afecta incluso infraestructuras críticas en Estados Unidos. Así, Sandworm dirigió un ciberataque a una instalación de agua de Muleshoe (Texas), en enero de 2024. Manipularon el sistema de control industrial (ICS), en la capa de suministro, y explotaron vulnerabilidades del *software* de gestión del agua.¹⁰ Un vídeo en Telegram, enviado por

⁹ Varonis, “Ransomware Statistics, Data, Trends, and Facts”, 2024,

[https://www.varonis.com/blog/ransomware-statistics#:~:text=Ransomware%20is%20an%20ever%2Dgrowing,\(Sophos\).](https://www.varonis.com/blog/ransomware-statistics#:~:text=Ransomware%20is%20an%20ever%2Dgrowing,(Sophos).)

¹⁰ Cyberscoop, “Mandiant: Notorious Russian hacking unit linked to breach of Texas water facility”, 2024, <https://cyberscoop.com/sandworm-apt44-texas-water-facility/>.

el colectivo CyberArmyofRussia_Reborn, asociado a Sandworm, mostró la alteración de configuraciones en la interfaz hombre-máquina (HMI) de la instalación. El incidente provocó un desbordamiento, pero el suministro del agua no se vio interrumpido.

No se trata de una novedad. Años antes, en mayo de 2018, el sistema de filtración de agua de Ucrania fue el blanco de un ciberataque mediante el uso del *malware* VPNFilter, con el objetivo de interrumpir el suministro de agua limpia del país. El *malware* en cuestión tenía la capacidad de deshabilitar cualquier *router* que infectara, lo que podría haber impedido el funcionamiento del sistema de cloración. Afortunadamente, fue bloqueado por el Servicio de Seguridad ucraniano,¹¹ quien afirmó que el ataque había sido cometido por atacantes patrocinados por el Kremlin.



Mensaje reivindicativo que el grupo CyberAv3ngers dejó en los equipos.

Análogamente, el conflicto de Oriente Medio también ha impulsado ciberataques con motivación geopolítica contra el sector del agua. En noviembre de 2023, 160 hogares conectados a un sistema de agua privado en el área de Erris (Irlanda)¹² quedaron sin suministro de agua durante varios días debido a un ciberataque. El ataque fue perpetrado por un grupo de ciberdelincuentes proiraníes que explotaron la vulnerabilidad CVE-2023-6448¹³ de un elemento de la capa de objetos: un PLC (*programmable logic controller*) de un sistema

de bombeo de agua. Dicha vulnerabilidad tenía su origen en el uso de la contraseña de administrador por defecto. Después del ataque, el grupo conocido como CyberAv3ngers dejó un mensaje en la red informática afectada, en el que declaraba que la motivación del ataque era el origen israelí del fabricante Unitronics.



¿Cuál es la funcionalidad de los PLC?

Un PLC es un dispositivo utilizado en entornos industriales, como en el sector del agua, para controlar el estado de elementos como las bombas de agua, la visualización de datos relevantes o la monitorización de la calidad del agua, entre otros.

Los casos de Sandworm y CyberAv3ngers constituyen ejemplos claros de cómo los grupos patrocinados por Estados disponen de capacidades para llevar a cabo ciberataques contra infraestructuras industriales, como las que operan en los servicios

¹¹ Sky News, “Russian hackers targeted Ukraine's water supply, security service claims”, 2018, <https://news.sky.com/story/russian-hackers-targeted-ukraines-water-supply-security-service-claims-11432826>.

¹² Irish Information Security Forum, “Did Cyber Av3ngers target Erris water Supply?”, 2023, <https://www.iisf.ie/Cyber-Av3ngers-target-Erris-water-supply>.

¹³ NIST, “National Vulnerability Database CVE-2023-6448 Detail”, 2023, <https://nvd.nist.gov/vuln/detail/CVE-2023-6448>.

de suministro de agua o tratamiento de aguas residuales. Se trata de entornos singulares, que requieren un alto nivel de habilidades técnicas, lo que evidencia la sofisticación y capacidad de estos grupos para comprometer sistemas complejos.

4.3. El *hacktivismo* se mezcla con la agenda geopolítica y amenaza las infraestructuras críticas con ataques complejos y destructivos

Los *hacktivistas* son aquellos autores de ciberataques que tienen el objetivo de promover ideas políticas, religiosas o sociales. Esta motivación contrasta con la de otros grupos ciberdelinquentes que buscan obtener beneficios o, simplemente, provocar daños a través del secuestro de información o de la interrupción de sistemas. Los colectivos *hacktivistas* pueden estar formados por múltiples individuos o grupos, de naturaleza heterogénea, pero con ideologías similares, y dirigen su actividad cibernética como forma de protesta contra Estados u organizaciones.

¿Qué es el *hacktivismo*?

Forma de activismo que utiliza internet como espacio de lucha ideológica, mediante la ejecución de acciones que entorpezcan la presentación normal de los sitios web o el funcionamiento de los sistemas informáticos de los grupos o instituciones que se pretende denunciar. (Fuente: Termcat)

Tradicionalmente, los *hacktivistas* han buscado generar un impacto mediático a través de ataques como la desfiguración de sitios web, el robo y filtración de datos, o ataques DDoS, sin tener implicaciones importantes a gran escala. No obstante, con el aumento de las tensiones y los actuales conflictos bélicos, su actividad se ha vuelto más destructiva e incorporan elementos como el sabotaje, las intrusiones y el uso de *wipers* o programas maliciosos destructivos.



¿Cómo funciona un *wiper*?

El propósito de un *wiper* es hacer que los datos sean inaccesibles e inutilizables. Sin embargo, a diferencia de un *ransomware*, su objetivo no es restaurar el acceso a la información después del pago del rescate, sino destruir esa información de forma permanente.

En esta línea, en 2024, se observó a dos grupos de *hacktivistas* rusos atacando infraestructuras críticas en varios países del mundo, especialmente en los sectores del

agua, petróleo y gas, como represalia al apoyo a Ucrania. Los responsables, los *hacktivistas* de People's Cyber Army (PCA) y Z-Pentest, publicaron vídeos en sus canales de Telegram mostrando cómo manipulaban, supuestamente, los controles OT de infraestructuras críticas.¹⁴

Anteriormente, en 2023, en el Valle del Jordán (Israel), un incidente cibernético supuso el compromiso de la seguridad de los sistemas de monitorización del agua, esenciales para el riego y el tratamiento del agua en la región. A pesar de las advertencias previas de las autoridades israelíes, que recomendaron desconectar las conexiones remotas, varias granjas no lo hicieron y sus sistemas fueron atacados y vulnerados.¹⁵ Aunque el incidente no fue reivindicado por ningún grupo o nación, se sospecha que podría estar relacionado con el movimiento OPIsrael, iniciado por Anonymous en 2012¹⁶ con el objetivo de protestar contra las políticas israelíes, especialmente en el contexto del conflicto palestino-israelí.¹⁷

4.4. El *ransomware* demuestra que puede poner en riesgo el operativo de la infraestructura hídrica

Los ataques de *ransomware* han emergido como una amenaza cibernética de gran envergadura, especialmente para servicios esenciales como el sector del agua. Este tipo de ciberataques obliga a las organizaciones víctimas a pagar un rescate para recuperar el acceso a su información. Aunque las motivaciones detrás de estos ataques suelen ser principalmente económicas, los objetivos de los ataques de *ransomware* a menudo están influenciados por intereses políticos o ideológicos.

¿Qué es el *ransomware*?

Software malicioso que restringe total o parcialmente el acceso a los archivos de un dispositivo hasta que no se paga una determinada cantidad de dinero. (Fuente: Termcat)

El sector del agua, en particular, se ha convertido en un objetivo especialmente atractivo para los cibercriminales dedicados al *ransomware*, debido a la naturaleza vital de sus operaciones. Un ataque exitoso a una entidad del sector del agua puede provocar interrupciones significativas en el suministro, lo que afecta tanto a los consumidores

¹⁴ SC Media, "Russian hackers target oil, gas and water sectors worldwide", 2024, <https://www.scworld.com/news/russian-hackivist-groups-target-oil-and-gas-and-water-sectors-worldwide>.

¹⁵ The Jerusalem Post, "Cyber attack leaves irrigation systems in Upper Galilee dysfunctional", 2023, <https://www.jpost.com/israel-news/article-738790>.

¹⁶ Radware, "OPIsrael: A Decade in Review", 2013, <https://www.radware.com/security/threat-advisories-and-attack-reports/opisrael-a-decade-in-review/>.

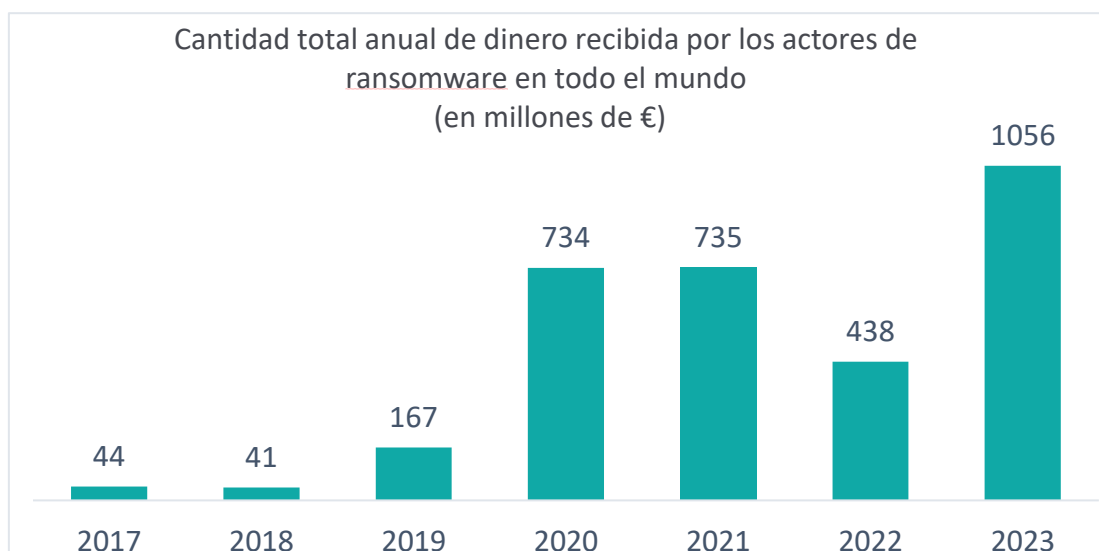
¹⁷ The Jerusalem Post, "Here's how to protect yourself from Anonymous cyberattacks next week", 2023, <https://www.jpost.com/business-and-innovation/tech-and-start-ups/article-735071>.

como a las industrias dependientes. Por este motivo, los atacantes dirigen sus esfuerzos a cifrar partes esenciales de los sistemas de información con el objetivo de interrumpir las operaciones del ciclo del agua y que, en consecuencia, las víctimas se dispongan a pagar rescates importantes para restaurar el acceso rápidamente.

💡 ¿Qué cifra un *ransomware*?

Un ataque por *ransomware* cifra elementos de un sistema variados, desde la información o datos personales hasta la pantalla o cualquier dispositivo periférico, para impedir el acceso a la información o el funcionamiento de los sistemas y coaccionar al usuario a pagar un rescate.

Los responsables de estos ataques son grupos de ciberdelincuentes organizados que trabajan en la modalidad de *ransomware as a service*. Se trata de un esquema que permite a los desarrolladores del *ransomware* vender su código malicioso a otros ciberdelincuentes, que, conocidos como “afiliados”, llevan a cabo los ciberataques. Este modelo ha contribuido a un aumento en la frecuencia y sofisticación de los ataques de *ransomware* a nivel global, a la vez que facilita la entrada de nuevos actores en el mundo del cibercrimen, dado que democratiza el acceso a herramientas avanzadas y soporte técnico para efectuar los ataques. Esta situación se explica con el aumento de la cantidad de dinero total anual recibida por los actores de *ransomware* y subraya la gravedad del problema.¹⁸



¹⁸ Statista, “Total annual amount of money received by ransomware actors worldwide from 2017 to 2023”, 2024, <https://www.statista.com/statistics/1410498/ransomware-revenue-annual/>.

Los métodos utilizados por los atacantes para infiltrarse en estas infraestructuras son variados, pero principalmente consisten en:

- *Phishing*: los ciberdelincuentes utilizan correos electrónicos de *phishing* para engañar a los empleados y lograr que revelen sus credenciales de acceso o descarguen *software* malicioso.
- Explotación de vulnerabilidades: los atacantes buscan y aprovechan fallos de seguridad para infiltrarse en los sistemas.
- Acceso remoto con credenciales robadas: los atacantes compran credenciales en el mercado negro conseguidas mediante *phishing* o *malware* para acceder remotamente a los sistemas de la víctima.

Un ejemplo de las consecuencias de un ataque de *ransomware* en el sector del agua lo hallamos en un suceso acaecido en agosto de 2022 en Montenegro.¹⁹ Durante dicho incidente, varios sectores críticos, incluido el suministro de agua, fueron objeto de un sofisticado ciberataque atribuido al grupo de *ransomware* conocido como Cuba. La infraestructura se vio seriamente comprometida, lo que hizo necesario implementar procesos manuales para mantener la operatividad y asegurar la disponibilidad del agua.

A pesar de la gravedad de sufrir un ataque por *ransomware*, las consecuencias pueden ser mitigadas a través de una actuación rápida y eficaz. Este fue el caso de la compañía estadounidense WSSC Water, dedicada a la filtración y tratamiento del agua. En 2021 sufrió un ataque por *ransomware*, pero gracias a las medidas de seguridad implantadas, se pudo bloquear la intrusión en sus sistemas de información y evitar que la calidad del agua se viera afectada.²⁰ A pesar de la rápida actuación, los cibercriminales sí pudieron acceder a los datos personales de los clientes. Por ello, la organización WSSC Water ofreció a todos sus clientes un seguro de robo de identidad por valor de 1 000 000 de dólares durante cinco años, en caso de que se vieran afectados por dicho ataque.²¹

En España, la concesionaria del Servicio Municipal de Abastecimiento de Agua Potable, Grupo FCC-Aqualia, sufrió un ataque de *ransomware* en 2023. Aunque no se ha publicado mucha información sobre el incidente, se sabe que afectó la disponibilidad de los datos durante unas horas pero no hubo una interrupción del servicio.²²

En resumen, los ataques de *ransomware* en el sector del agua pueden acarrear impactos muy importantes. No solo interrumpen servicios vitales, sino que también conllevan altos costes económicos y riesgos para la privacidad de los datos. La implementación de medidas de seguridad robustas, como las copias de seguridad adecuadas y equipos de respuesta rápida, es fundamental para minimizar el daño y proteger tanto la infraestructura como la información confidencial de los clientes.

¹⁹ Malware News, “Montenegro struggles to recover from cyberattack that officials blame on Russia”, 2022, <https://malware.news/t/montenegro-struggles-to-recover-from-cyberattack-that-officials-blame-on-russia/62970>.

²⁰ CBS News, “WSSC Water Investigating Ransomware Attack”, 2021, <https://www.cbsnews.com/baltimore/news/wssc-water-investigating-ransomware-attack/>.

²¹ Security affairs, “US water company WSSC Water hit by a ransomware attack”, 2021, <https://securityaffairs.com/119700/cyber-crime/wssc-water-ransomware-attack.html>.

²² Ajuntament de Lleida, “Comunicación preventiva de un incidente de seguridad de datos personales sufrido por Aqualia”, <https://www.paeria.cat/es/actualidad/noticias/comunicacion-preventiva-de-un-incidente-de-seguridad-de-datos-personales-sufrido-por-aqualia>

4.5. Los ataques DDoS suponen un riesgo para las comunicaciones del sector hídrico en espacios abiertos

Por su naturaleza, las instalaciones de agua están ubicadas en su mayoría en espacios abiertos y, por lo tanto, la conectividad de los dispositivos se fundamenta en comunicaciones inalámbricas. Para distancias cortas o espacios interiores, las comunicaciones vía *bluetooth* o *wifi* son las más habituales y, cuando se requiere un largo alcance, se utilizan tecnologías móviles como las 3G, 4G, 5G y LTE (*long term evolution*). En cualquier caso, las comunicaciones inalámbricas son un elemento troncal en cuanto a una buena gestión del agua digitalizada, dado que permiten la transmisión eficiente y flexible de grandes volúmenes de datos en tiempo real desde ubicaciones remotas o de difícil acceso.

En dicho ámbito, la precisión en el monitoreo y la comprensión de las variaciones en los parámetros del agua, como la volumetría o la composición, son fundamentales. Esto se consigue a través de una infraestructura de sensores y de IoT, conectados a PLC y a concentradores de datos, distribuidos por el territorio. Los sensores y los IoT recogen los datos específicos del agua y del funcionamiento de la infraestructura, y los transmiten a PLC y a concentradores de datos con el objetivo de permitir la toma de decisiones en tiempo real. Sin embargo, esto demanda niveles de transferencia de datos cada vez más elevados y sin caídas de actividad. Es vital que las comunicaciones inalámbricas funcionen correctamente, puesto que una pérdida de conectividad puede acabar con serias complicaciones: pasar por alto una crecida del nivel del agua, ignorar una alteración de la potabilidad del agua, etc.

Los factores que pueden afectar el correcto funcionamiento de una red de comunicaciones vía radio son varios: las condiciones climatológicas, una catástrofe natural, una señal interferente, una interrupción en el suministro eléctrico, una incidencia técnica del proveedor del servicio, etc.

Además, las comunicaciones pueden verse afectadas a causa de actividades malintencionadas, como los ataques DoS o DDoS. A pesar de que estos ciberataques habitualmente van dirigidos a sectores fuertemente digitalizados, en los cuales una interrupción de la conectividad supone un problema crítico, en el contexto actual de digitalización del sector del agua también hay que tenerlos en cuenta.



¿Cuál es la diferencia entre un ataque DoS y un DDoS?

Un ataque DoS (del inglés *denial-of-service*) consiste en saturar la capacidad de procesamiento de nuevas conexiones del sistema objetivo a través de un único dispositivo. Un ataque DDoS (del inglés *distributed denial-of-service*) consiste en utilizar la misma técnica que un DoS, pero a través de numerosos dispositivos, para poder saturar sistemas capaces de establecer un mayor número de conexiones.

En este sentido, se ha demostrado que es posible dirigir un ataque de denegación de servicio (DoS) al punto de acceso wifi donde se conectan los sensores y dispositivos IoT para impedir la comunicación con un servidor central.²³

Por otro lado, hay que tener en cuenta que los dispositivos IoT, pese a disponer de conectividad, presentan limitaciones en la capacidad de procesamiento y seguridad, y esto los convierte en objetivos frecuentes de ataques. Los atacantes buscan explotar vulnerabilidades en estos sistemas para infectarlos con *malware* y convertirlos en parte de una *botnet* controlada remotamente. Una vez comprometidos, los IoT pueden ser utilizados para lanzar ataques contra objetivos de la propia red o externos, con el fin de colapsarlos y dejarlos fuera de servicio. Un ejemplo notable es la *botnet* Mirai, resultado de la propagación de un famoso *malware* capaz de comprometer dispositivos IoT (como cámaras de seguridad) y *routers* para utilizarlos para llevar a cabo ataques DDoS.²⁴

¿Qué es una *botnet*?

Grupo de ordenadores zombi que son controlados desde un mismo servidor y se hacen actuar conjuntamente. (Fuente: Termcat)

Este tipo de ataques se ha intensificado notablemente: Imperva²⁵ reportó un incremento del 111 % en la primera mitad de 2024 respecto al mismo periodo de 2023.

4.6. Las regulaciones y estándares promueven y exigen sistemas digitales resilientes para la continuidad del sector del agua

A raíz de la importancia de la disponibilidad de los servicios del agua, se ha desarrollado un marco regulador, tanto a nivel nacional como internacional, para asegurar que operan de manera resiliente, minimizando el riesgo cibernético a sufrir interrupciones.

Para empezar, en España, la Ley 8/2011,²⁶ conocida como Ley de Protección de Infraestructuras Críticas (PIC), establece un marco esencial que incluye el sector hídrico. Aunque no se centra específicamente en ciberseguridad, dicha ley subraya la necesidad de coordinar esfuerzos entre entidades públicas y privadas para prevenir interrupciones.

²³ International Journal of Computer Applications, “DoS Attacks in IoT Systems and Proposed Solutions”, 2020, <https://www.ijcaonline.org/archives/volume176/number33/abughazaleh-2020-ijca-920397.pdf>.

²⁴ Incibe, “Mirai”, 2024, <https://www.incibe.es/servicio-antibotnet/info/Mirai>.

²⁵ Imperva, “2024 Imperva DDoS Threat Landscape Report”, 2024, <https://www.imperva.com/resources/resource-library/reports/2024-imperva-ddos-threat-landscape-report/>.

²⁶ BOE, Ley 8/2011, de 28 de abril, por la que se establecen medidas para la protección de las infraestructuras críticas, <https://www.boe.es/buscar/pdf/2011/BOE-A-2011-7630-consolidado.pdf>.



Ya en el ámbito de la ciberseguridad, la Directiva NIS²⁷ (UE 2016/1148) fue todo un hito europeo que estableció un marco normativo para garantizar un elevado nivel de seguridad en las redes y sistemas de información en la Unión Europea. En España, esta directiva se transpuso mediante el Real Decreto-ley 12/2018²⁸ y el Real Decreto 43/2021,²⁹ los cuales definieron mecanismos para proteger servicios esenciales y digitales, en los que se incluía el sector del agua, y para promover la coordinación entre autoridades y equipos de respuesta a incidentes de seguridad informática (CSIRT).

Con el tiempo, la evolución de las amenazas cibernéticas puso de manifiesto las limitaciones de la Directiva NIS, lo que llevó a la promulgación de la Directiva NIS2³⁰ (UE 2022/2555), que amplía el ámbito de aplicación e introduce una nueva clasificación basada en entidades esenciales y entidades importantes. Precisamente, establece las entidades de los sectores del agua potable y de aguas residuales como esenciales, y reconoce su importancia crítica para la sociedad. Además, la NIS2 refuerza los requisitos de seguridad, mejora los procesos de notificación de incidentes, aborda la seguridad en la cadena de suministro, y fomenta el intercambio de información y la divulgación de vulnerabilidades.

En España, en enero de 2025, se aprobó el anteproyecto de ley que transpone la Directiva NIS2, lo que refuerza el marco normativo nacional para asegurar una protección más robusta del sector hidráulico frente a las ciberamenazas.

Aparte de las regulaciones de ciberseguridad mencionadas, existen varios estándares que describen las mejores prácticas para asegurar la continuidad de la operatividad. Precisamente, la ISO 22301³¹ supone un estándar internacional para la seguridad y resiliencia que proporciona un marco para establecer, implementar y mejorar un sistema de gestión de continuidad del negocio. Por otro lado, la serie ISO/IEC 62443³² establece directrices para proteger los sistemas de automatización y control industrial, cruciales para mejorar la seguridad en los sistemas industriales existentes en la infraestructura del sector hídrico.

²⁷ BOE, Directiva (UE) 2016/1148 del Parlamento Europeo y del Consejo, 2016, <https://www.boe.es/doue/2016/194/L00001-00030.pdf>.

²⁸ BOE, Real Decreto-ley 12/2018, de 7 de septiembre, de seguridad de las redes y sistemas de información, <https://www.boe.es/eli/es/rdl/2018/09/07/12/dof/spa/pdf>.

²⁹ BOE, Real Decreto 43/2021, de 26 de enero, por el que se desarrolla el Real Decreto-ley 12/2018, de 7 de septiembre, de seguridad de las redes y sistemas de información, <https://www.boe.es/boe/dias/2021/01/28/pdfs/BOE-A-2021-1192.pdf>.

³⁰ Incibe, “Aprobación de la Directiva NIS2”, 2023, <https://www.incibe.es/incibe-cert/publicaciones/bitacora-de-seguridad/aprobacion-directiva-nis2>.

³¹ Wikipedia, “ISO 22301”, 2012, <https://www.bsigroup.com/LocalFiles/en-IN/Certification/ISO%2022301/ISO-22301-Implementation-Guide-web.pdf>.

³² Incibe, “El IEC62443-4-2, la necesidad de securizar los componentes”, 2022, <https://www.incibe.es/incibe-cert/blog/el-iec-62443-4-2-necesidad-securizar-los-componentes>.

4.7. Recomendaciones



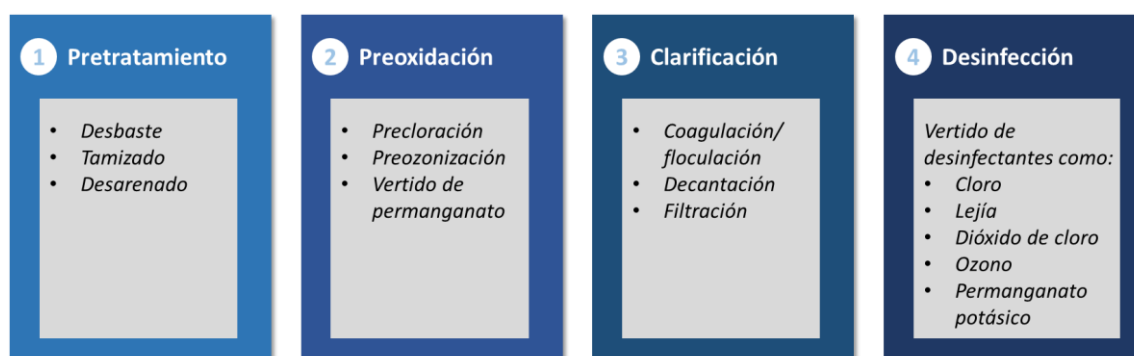
Es necesario que las organizaciones involucradas en el sector del agua:

- **Conozcan** el entorno de su negocio en materia de ciberseguridad para poder identificar qué actores maliciosos con relevancia, ya sean APT o grupos *hacktivistas*, son una amenaza directa.
- **Analicen** la procedencia de sus componentes para conocer la probabilidad de ser objetivo de ciberataques por parte de los actores mencionados previamente.
- **Formen y conciencien** a sus empleados para detectar situaciones anómalas que puedan resultar ser un ciberataque.
- **Establezcan** un plan de continuidad de negocio y un plan de recuperación de desastres en funcionamiento para minimizar el impacto de un ciberataque por *ransomware* o de un desastre natural.
- **Dispongan** de copias de seguridad actualizadas y fuera de línea, para evitar que el *ransomware* también pueda cifrarlas.
- **Implementen** soluciones que permitan mantener actualizados los sistemas operativos, los *firmwares* y los programas, así como los *antimalware* o antivirus, con los últimos patrones de código malicioso.
- **Protejan** los recursos esenciales visibles desde internet mediante protecciones anti-DDoS.
- **Anticipen y analicen** los cambios reguladores para asegurar el cumplimiento y la adaptación a nuevas normativas.

5. La amenaza de sabotajes a la integridad de los datos en el sector y sus consecuencias

A lo largo del ciclo de vida del agua, las entidades del sector hídrico necesitan supervisar su estado en cada etapa, así como gestionar la infraestructura de control, para tomar decisiones basadas en datos tangibles. Únicamente con un conocimiento detallado de la situación del agua y los sistemas involucrados en cada momento, es posible garantizar un abastecimiento de agua de calidad para el consumo urbano, agrícola e industrial. Además, este enfoque optimiza su reutilización y reduce el desperdicio.

Tradicionalmente, en el tratamiento del agua, se establecen varios procedimientos para su purificación y potabilización, que se pueden agrupar en las siguientes fases:³³



En cada uno de los tratamientos, el uso de productos químicos debe estar controlado para garantizar que el proceso sea adecuado y evitar problemas de salud pública; además, se debe cumplir lo estipulado en la legislación en referencia a la calidad del agua de consumo.³⁴ Para lograrlo, es fundamental disponer de datos correctos y completos sobre el rendimiento del ciclo de vida del agua, en tiempo real y desde que se capta hasta que se consume. Estos datos son esenciales para garantizar que las operaciones se realicen de manera eficiente y segura, dado que un error en los datos en cualquiera de las fases puede afectar a las demás, comprometer la calidad del agua y ocasionar un riesgo para la salud pública.

Para abordar estos desafíos, el sector está adoptando tecnologías avanzadas, como el internet de las cosas (IoT), la computación en la nube o la inteligencia artificial (IA). El IoT conecta sensores para monitorizar variables clave —como flujo, presión y calidad del agua—, mientras que la nube proporciona almacenamiento seguro y accesible de datos. La IA analiza patrones en grandes volúmenes de datos para apoyar la toma de decisiones, aunque su efectividad depende de la calidad de los datos disponibles.

³³ Spain Business, *Ciclo integral del agua en España. Potabilización, depuración y reutilización*, 2007, <https://www.acuamed.es/sites/default/files/publicaciones/ciclo-integral-agua-espana.pdf>.

³⁴ BOE, Real Decreto 3/2023, de 10 de enero, por el que se establecen los criterios técnico-sanitarios de la calidad del agua de consumo, su control y suministro, <https://www.boe.es/buscar/act.php?id=BOE-A-2023-628>.

Aspectos a tratar:

- ✓ El tratamiento del agua es objetivo potencial de ciberataques para impactar en la salud pública mediante la manipulación de sistemas.
- ✓ El uso de la tecnología *legacy* incrementa la posibilidad de sufrir ciberataques.
- ✓ La IA y el IoT transforman la gestión del agua y mejoran la monitorización y el tratamiento.
- ✓ La proliferación de bulos y la falta de veracidad de la información pública amenazan la estabilidad social y la salud pública.
- ✓ Las vulnerabilidades en proveedores externos amenazan la seguridad de la cadena de suministro del agua.
- ✓ Los accesos privilegiados de los trabajadores de las entidades del agua amenazan la manipulación de los sistemas de tratamiento.

5.1. El tratamiento del agua es objetivo potencial de ciberataques para impactar en la salud pública mediante la manipulación de sistemas

En un sector del agua digitalizado, la gestión del agua depende de los datos y de los sistemas de información, hasta el punto de que un incidente cibernético que afecte su integridad puede llevar a la toma de decisiones erróneas, al desperdicio de agua y a la pérdida de tiempo, esfuerzos y dinero. Y, por supuesto, una manipulación de un sistema de información del sector del agua también podría generar problemas en la calidad del agua y perjuicios para la salud de los consumidores.

En este punto, los riesgos del mundo digital convergen con el mundo físico, de modo que un ciberataque que logre manipular los sistemas de información podrá impactar sobre la gestión operativa del agua. Por ejemplo, una alteración intencionada de los datos puede forzar la decisión de abrir o cerrar compuertas en un momento inoportuno, cambiar las proporciones de los productos químicos utilizados en el tratamiento del agua, modificar la temperatura de almacenamiento del agua, aprobar incorrectamente el uso de una nueva tecnología de filtrado, falsear una alerta por contaminación química, etc.

No son escenarios alejados de la realidad. En 2019, un ciberdelincuente sin afiliación a ningún grupo *hacktivista* o de APT, accedió a los sistemas de información de unas instalaciones rurales de agua en el condado de Ellsworth (Estados Unidos). Los manipuló

y provocó la detención del proceso de purificación y desinfección del agua.³⁵ El incidente afectó a un total de 6100 personas que habitan el condado, ya que las desabasteció de agua limpia y potable.

En otro caso similar, también en Estados Unidos, en marzo de 2021, un ciberatacante *amateur* consiguió acceder a los sistemas de información de la planta de tratamiento de agua de Oldsmar. Intentó aumentar los niveles de hidróxido de sodio (lejía) del agua de 10 partes por millón a 11 100 partes por millón,³⁶ lo que habría supuesto un grave peligro para la salud pública debido a la alta corrosividad de dicho componente, pero fue detectado a tiempo.

Dada la demostrada posibilidad de impactar en la salud pública mediante la manipulación de los sistemas de información dedicados al tratamiento y distribución de agua, este sector resulta un objetivo potencial para actores con motivación ciberterrorista o enmarcada en un contexto de ciberguerra. Detrás de estos ciberataques sofisticados, además de individuos malintencionados como los de los ejemplos precedentes, se puede esconder el sigilo de los actores-Estado o el profesionalismo de grupos mercenarios.

5.2. Los sistemas antiguos con conectividad plantean un auténtico desafío para la ciberseguridad del sector del agua

La exposición del sector hídrico a los ciberataques no solo responde a su importancia estratégica, sino también a las limitaciones en ciberseguridad inherentes a las tecnologías industriales sobre las que opera su infraestructura. La digitalización ha supuesto un cambio de paradigma en el sector, dado que se han integrado las modernas tecnologías de la información (IT) sobre las tradicionales tecnologías operativas (OT) de la industria. Esta interconexión ha generado nuevos desafíos de seguridad, ya que muchos de los sistemas industriales fueron diseñados para un contexto diferente, sin considerar la conectividad y las amenazas cibernéticas actuales. Este tipo de tecnologías, conocidas como tecnologías *legacy*, presentan limitaciones de seguridad que suponen un riesgo en las operaciones del sector del agua al que hay que hacer frente.

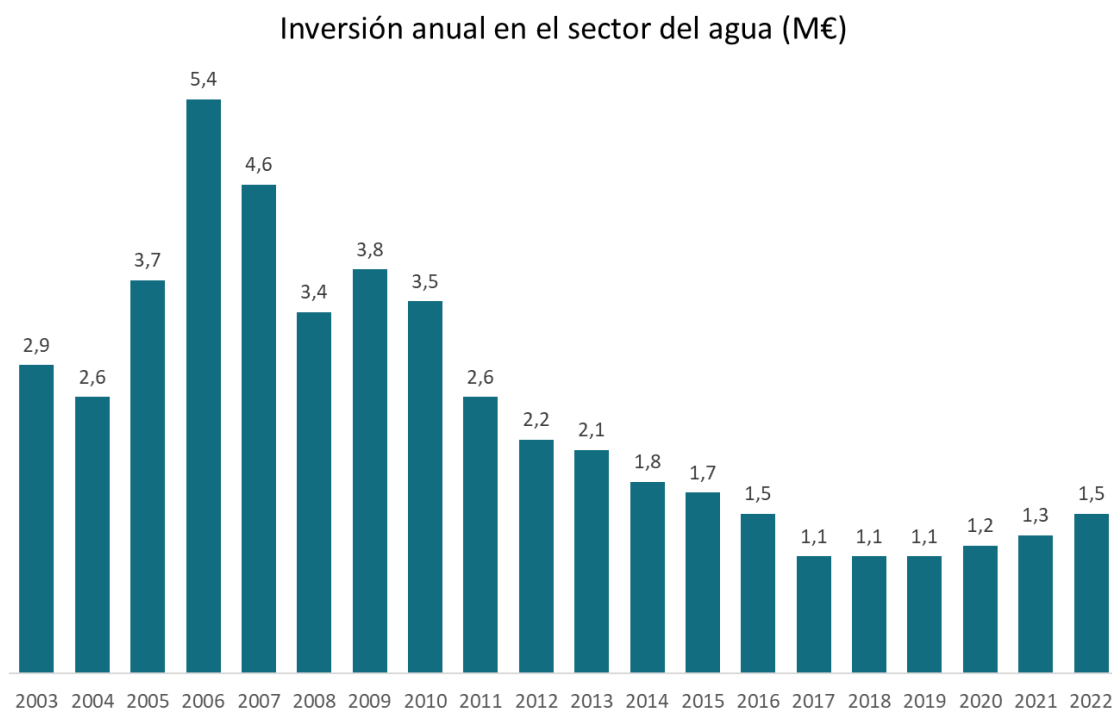
En España, la existencia de estas tecnologías *legacy* en el sector del agua se agrava por la baja inversión, la cual alcanza menos del 50 % de lo necesario y acarrea un déficit significativo. De hecho, desde la crisis económica de 2008-2012, la inversión en el ciclo urbano del agua ha disminuido drásticamente: durante el periodo 2003-2010³⁷ se destinaban entre 2600 y 5400 millones de euros anuales, pero esta cifra se ha reducido a una horquilla entre 1100 y 1500 millones de euros anuales entre 2016 y 2022. Esta reducción supone un descenso superior al 50 %, que afecta tanto a la administración

³⁵ United States Attorney's Office, "Indictment: Kansas man indicted for tampering with a public water system", 2021, <https://www.justice.gov/usao-ks/pr/indictment-kansas-man-indicted-tampering-public-water-system>.

³⁶ CSO, "Oldsmar cyberattack raises importance of water utility assessment, training", 2021, <https://www.csoonline.com/article/570345/oldsmar-cyberattack-raises-importance-of-water-utility-assessments-training.html>.

³⁷ Asociación Agua, *Estimación del déficit de inversiones en el ciclo urbano del agua en España*, 2024, <https://asociacionagua.com/wp-content/uploads/2024/06/Análisis-del-deficit-de-agua-urbano.pdf>.

pública como a los operadores privados, quienes no han podido mantener los niveles de inversión necesarios. Dicha evolución se refleja en la siguiente ilustración:



La inversión insuficiente provoca la obsolescencia de los sistemas hídricos, lo que, a su vez, incrementa la vulnerabilidad a ciberataques. Un ejemplo de ello tuvo lugar en 2024 en Estados Unidos, donde un ataque cibernético comprometió una planta de tratamiento de aguas residuales en Tipton.³⁸ Unos ciberatacantes de origen ruso accedieron a los sistemas aprovechando la incorporación de conectividad en un entorno industrial tradicionalmente cerrado. Utilizaron un servicio de acceso remoto para infiltrarse en los sistemas de control y manipular el *software* que gestiona el equipo de tratamiento de aguas. Afortunadamente, el personal de la planta detectó rápidamente la actividad sospechosa y envió personal de mantenimiento para investigar, por lo que se minimizaron las interrupciones operativas.

Tal y como se ha destacado, las infraestructuras industriales, y concretamente las del sector del agua, son vulnerables a las ciberamenazas por la existencia de tecnología *legacy* y la falta de recursos para actualizarla previendo los nuevos desafíos. No cabe duda de que una adecuada inversión y la modernización de las infraestructuras hídricas son esenciales para asegurar la resiliencia de un suministro básico como el agua.

³⁸ CNN, “Russian-linked hacking group claims to have target Indiana water plant”, 2024, <https://edition.cnn.com/2024/04/22/politics/russia-linked-hacking-group-targets-indiana-water-plant/index.html>.

5.3. La integración de IA y de IoT optimiza la gestión del agua, pero introduce desafíos en la seguridad de los datos

Hoy en día, el sector del agua se enfrenta a múltiples desafíos, incluyendo la sequía, el aumento de demanda del agua y el riesgo de desastres naturales cada vez más extremos. Con el objetivo de encontrar soluciones y mejorar el ciclo de vida del agua, las empresas apuestan por la incorporación de nuevas tecnologías, como el IoT y la IA.

El IoT facilita el monitoreo y la gestión en tiempo real, mediante sensores y actuadores que pueden medir el caudal, la calidad del agua o posibles fugas en la red. Por su parte, la IA puede emplearse para predecir patrones de consumo, optimizar el tratamiento del agua o anticipar los fallos en la infraestructura, lo que permitirá mejorar la eficiencia y reducir desperdicios. De este modo, mientras que el IoT ofrece la infraestructura para la recopilación de datos, la IA proporciona la capacidad analítica para mejorar la eficiencia y efectividad de la gestión del agua.

¿Qué es la IA?

Rama de la informática dedicada al desarrollo de algoritmos que permiten a un ordenador percibir su entorno lógico y tomar decisiones para maximizar sus posibilidades de éxito en una o más tareas. *(Fuente: Termcat)*

De hecho, el IoT y la IA ya se están utilizando de manera aplicada para las siguientes actividades del tratamiento del agua:³⁹

- **Determinación de la calidad.** Los dispositivos IoT y los sensores colocados en las reservas e infraestructuras recogen datos en tiempo real, que luego son analizados por IA para detectar contaminantes o patógenos.⁴⁰
- **Coagulación/floculación.** La IA optimiza la identificación de la dosis óptima de agentes coagulantes, lo que reduce un 10 % los costes en dicho proceso.⁴¹

³⁹ ScienceDirect, "A review of artificial intelligence in water purification and wastewater treatment: Recent advancements", 2022,

<https://www.sciencedirect.com/science/article/abs/pii/S2214714422004184#preview-section-snippets>.

⁴⁰ Environmental Finance Center Network, "AI in Water Management: Six Ways Artificial Intelligence Can Help Solve Problems Across the Water Sector", 2024, <https://efcnetwork.org/ai-in-water-management-six-ways-artificial-intelligence-can-help-solve-problems-across-the-water-sector/#:~:text=By%20analyzing%20data%20from%20sensors,plumes%20and%20waterborne%20diseases%20pathogens>.

⁴¹ ScienceDirect, "Revolutionizing wastewater treatment toward circular economy and carbon neutrality goals: Pioneering sustainable and efficient solutions for automation and advanced process control with smart and cutting-edge technologies", 2024, <https://www.sciencedirect.com/science/article/pii/S2214714424007189>.

- **Desalinización.** La concentración de sal en el agua puede variar dependiendo de un amplio abanico de posibilidades, y la IA puede ayudar a predecirla con éxito.⁴²
- **Retirada de metales pesados.** La presencia de dichas sustancias es altamente variable y no lineal, por lo que la selección de un modelo de IA es un proceso todavía en desarrollo.⁴³
- **Monitorización de los productos químicos.** Los dispositivos IoT y sensores detectan en tiempo real la presencia de productos químicos en el agua, y la IA analiza estos datos para determinar si el agua está limpia, contaminada o tratada.⁴⁴

A pesar de sus ventajas, dichas tecnologías requieren la integridad de la información como elemento esencial para su correcto funcionamiento. De hecho, la presencia de información errónea puede llevar a la toma de decisiones equivocadas en procesos críticos.

Por un lado, existe un riesgo vinculado a los dispositivos IoT. Sus limitaciones en ciberseguridad los convierten en un objetivo vulnerable a ciberataques, ya que podrían permitir la manipulación de los datos que alimentan la toma de decisiones por parte de la IA. Esto podría llevar a decisiones erróneas sobre la calidad del agua o la detección de contaminantes, lo que comprometería tanto la seguridad como la eficiencia del tratamiento.

¿Qué es el IoT?

Red formada por un conjunto de objetos conectados a internet que se pueden comunicar entre sí y también con humanos, y así transmitir y tratar datos con o sin intervención humana. (Fuente: Termcat)

Por otro lado, la IA puede verse comprometida a través de ataques de envenenamiento de datos, una técnica en la que se introducen datos maliciosos en su fase de modelado y entrenamiento. Esto podría sesgar los modelos, y reducir su capacidad para optimizar procesos clave como la coagulación/floculación o la desalinización. Como resultado, los sistemas inteligentes entrenados con datos manipulados podrían operar de modo ineficiente o peligroso.

El robo o filtración de modelos de IA y sus datos permite a los atacantes analizar su funcionamiento, identificar vulnerabilidades y diseñar ataques más sofisticados. Con esta información, pueden manipular datos de entrada para engañar a la IA, alterar su

⁴² Saudi Water Authority, "AI Applications in The Desalination Industry", 2024, <https://swa-cdn.swa.gov.sa/Reports/AIReport-SoftCopy.pdf>.

⁴³ ScienceDirect, "Development of artificial intelligence for modeling wastewater heavy metal removal: State of the art, application assessment and possible future research", 2020, <https://www.sciencedirect.com/science/article/abs/pii/S0959652619343434>.

⁴⁴ ScienceDirect, "Real-time water quality monitoring using AI-enabled sensors: Detection of contaminants and UV disinfection analysis in smart urban water system", 2024, <https://www.sciencedirect.com/science/article/pii/S1018364724003215>.

entrenamiento o incluso replicar el sistema sin inversión propia. En el sector del agua, esto no solo supone un riesgo operativo y económico, sino que también puede comprometer la seguridad y la calidad del servicio.

5.4. La proliferación de bulos y la falta de veracidad de la información pública amenazan la estabilidad social y la salud pública

En la sociedad hiperconectada actual, se puede encontrar información de cualquier tipología, ya sea correcta o errónea. De hecho, la abundancia y diversidad de información disponible en internet y en las redes sociales favorece la aparición de bulos o información contradictoria en relación con la emitida por fuentes oficiales. A menudo, las informaciones falsas surgen del desconocimiento popular, pero en ocasiones se falsean deliberadamente para influir en la opinión pública, promover agendas específicas y desestabilizar países, lo que socava la confianza en instituciones y figuras públicas, sobre todo durante etapas especialmente críticas. Se crea, así, un ambiente de confusión y desconfianza generalizada.

Por ejemplo, tras lo ocurrido con la dana en 2024, surgió un bulo que decía que el gran volumen de agua que cayó provocó la rotura de la presa de Forata,⁴⁵ la cual retiene 27 hectómetros cúbicos de agua.⁴⁶ En dicho bulo, se puede observar una gran riada que inunda una carretera y arrasa los coches que se encuentra por delante. Más tarde, se confirmó que era un vídeo de un torrente de agua en Bolivia. Probablemente, los creadores del bulo querían generar desconfianza en las instituciones, sugiriendo que las inundaciones habían sido provocadas deliberadamente al abrir la presa.

Un ejemplo claro de desinformación con fines ideológicos se puede observar en las declaraciones emitidas por Robert F. Kennedy Jr.⁴⁷ en junio de 2022, entonces candidato a presidente de los Estados Unidos. Las declaraciones exponían claramente que los elementos químicos que contiene el agua potable afectan directamente el sistema endocrino de los niños y adolescentes, lo que puede incluso implicar un cambio en la orientación sexual o en la identidad sexual. Dichas declaraciones llegaban a afirmar que existían ejemplos de ranas que habían mutado de macho a hembra y habían empezado a producir huevos, con el objetivo de justificar sus declaraciones.

⁴⁵ RTVE, “DANA Valencia: No es un desbordamiento por la llegada del agua de la presa de Forata, es un bulo”, 2024, <https://www.rtve.es/noticias/20241113/dana-valencia-no-desbordamiento-por-llegada-del-agua-presa-forata-bulo/16329022.shtml>.

⁴⁶ Embalses.net, “Embalse: Forata (Tiempo Real)”, 2024, <https://www.embalses.net/pantano-640-forata.html>.

⁴⁷ CNN, “Robert F. Kennedy Jr. repeatedly suggested that chemicals in water are impacting sexuality of children”, 2023, <https://edition.cnn.com/2023/07/13/politics/robert-kennedy-jr-chemicals-water-children-frogs/index.html>.

5.5. El compromiso de los proveedores de *software*, servicios remotos y plataformas de datos también es un vector de ataque

La creciente complejidad y especialización de la tecnología y los dispositivos utilizados en distintas actividades obliga a las organizaciones a buscar el apoyo de proveedores especializados. Estos proveedores no solo suministran la tecnología y los dispositivos necesarios, sino que también ofrecen servicios operativos y de mantenimiento de la infraestructura. Sin embargo, esta dependencia de proveedores externos puede representar un riesgo significativo para la seguridad de la información de las organizaciones.

Los actores maliciosos pueden realizar ciberataques a través de los proveedores para alcanzar a sus clientes, que son su verdadero objetivo. Utilizan proveedores de servicios de seguridad gestionada (MSSP) para comprometer accesos remotos; infiltran proveedores de *software* para difundir código malicioso, o atacan proveedores de plataformas de datos para acceder a los datos de los clientes.

Un ejemplo paradigmático del uso de accesos remotos por parte de proveedores externos para realizar el mantenimiento de las máquinas es el incidente de la planta de tratamiento de agua de Oldsmar (Estados Unidos), descrito anteriormente. En ese caso, el atacante consiguió acceso a los sistemas de información a través de unas credenciales robadas del programa TeamViewer, usado para el mantenimiento remoto, lo que le permitió tener un acceso directo para llevar a cabo los cambios sin problemas. Posteriormente, intentó alterar peligrosamente los niveles de hidróxido de sodio en el agua.

Un ejemplo de ataque a proveedores de *software* es el que ocurrió en junio de 2020, cuando la empresa SolarWinds fue víctima de un ciberataque por parte de, presuntamente, la APT rusa Cozy Bear,⁴⁸ también conocida como APT29. El actor malicioso introdujo un código malicioso *backdoor* en una actualización de su plataforma Orion, usada para monitorizar y gestionar activos TIC corporativos desde una sola consola, lo que provocó que un número importante de clientes resultaran infectados,⁴⁹ entre ellos Helix Water,⁵⁰ una entidad pública para distribuir agua en los suburbios de San Diego (Estados Unidos).

Finalmente, un ejemplo de ciberataques a proveedores de plataformas de servicios de datos fue el caso de MOVEit, en 2023. Los cibercriminales responsables del *ransomware* Clop explotaron una vulnerabilidad en el *software* MOVEit Transfer,⁵¹ ampliamente utilizado para la transferencia de archivos, que permitió acceder y extraer datos de más de 2600 organizaciones. Entre los afectados, también figuraban entidades de suministro

⁴⁸ TechTarget, "SolarWinds hack explained: Everything you need to know", 2023, <https://www.techtarget.com/whatis/feature/SolarWinds-hack-explained-Everything-you-need-to-know>.

⁴⁹ National Cyber Security Centre, "NCSC Annual Review 2021", 2021, <https://www.ncsc.gov.uk/collection/ncsc-annual-review-2021/the-threat/solarwinds>.

⁵⁰ Security Affairs, "Researchers shared the list of victims of solarwinds Hack", 2020, <https://securityaffairs.com/112555/hacking/solarwinds-victims-lists.html>.

⁵¹ Cyber Magazine, "Amazon: How MOVEit Supply Chain Attack Left Eching Effectgts", 2024, <https://cybermagazine.com/articles/amazon-how-moveit-supply-chain-attack-left-lasting-effects>.

de agua: Halifax Water (Canadá) notificó a aproximadamente 25 000 clientes que sus nombres y números de cuenta se vieron comprometidos por la brecha de seguridad.⁵²

Las organizaciones del sector del agua deben asegurarse de que sus proveedores cuenten con un nivel adecuado de ciberseguridad para proteger sus infraestructuras críticas. Para lograrlo, pueden requerir la realización de auditorías exhaustivas; verificar la disponibilidad de certificaciones de ciberseguridad reconocidas internacionalmente, como ISO/IEC 27001, o utilizar herramientas avanzadas de calificación de seguridad para analizar y monitorear continuamente la postura de seguridad de sus proveedores. Estas medidas no solo ayudan a mitigar riesgos, sino que también fomentan una cultura de seguridad proactiva y colaborativa en toda la cadena de suministro.

5.6. El acceso privilegiado de empleados internos amenaza la seguridad de los sistemas industriales del agua

El sector del agua, cada vez más digitalizado, se enfrenta a nuevas amenazas a medida que sus sistemas de información se vuelven más complejos y accesibles. Los empleados con acceso privilegiado a dichos sistemas pueden causar daños significativos, ya sea de modo involuntario o intencionado. Esta situación se conoce como amenaza interna o *insider threat*, y puede estar motivada por distintas razones: errores involuntarios por falta de capacitación o negligencia, venganza derivada del descontento o de conflictos laborales, incentivos financieros ofrecidos por terceros o coerción bajo amenazas externas.

Uno de los mayores riesgos de la amenaza interna es la existencia de accesos privilegiados, que permiten a un actor interno ejecutar tareas críticas, pero también representan un peligro si no se administran de modo adecuado. En 2021, en Discovery Bay, California (Estados Unidos), un ex empleado de un proveedor contratado por la empresa de aguas fue acusado de hackear los sistemas informáticos de la planta de tratamiento de aguas. Este ex empleado instaló *software* en su computadora personal y en la red interna de la planta para acceder remotamente al sistema. Después de renunciar a su trabajo, utilizó este acceso remoto para desinstalar el *software* principal que controlaba la operación del sistema de tratamiento de aguas, lo que puso en riesgo la seguridad del suministro de agua para los 15 000 residentes de la ciudad.⁵³

No es el único caso en el que un empleado o ex empleado resentido trata de provocar un incidente de seguridad. En marzo de 2019, en Kansas (Estados Unidos),⁵⁴ un ex empleado del Distrito de Agua Rural de Post Rock accedió ilegalmente al sistema de la planta de

⁵² Ckbw, "Province identifies more groups impacted by MOVEit breach", 2023, <https://www.ckbw.ca/2023/06/14/province-identifies-more-groups-impacted-by-moveit-breach/>.

⁵³ Security affairs, "A man has been charged with a cyber attack on the discovery bay water treatment facility", 2023, <https://securityaffairs.com/148258/cyber-crime/discovery-bay-water-treatment-facility-attck.html>.

⁵⁴ Governing, "Ex-Employee Remotely Hacks Kansas Water Treatment Plant", 2021, <https://www.governing.com/security/ex-employee-remotely-hacks-kansas-water-treatment-plant.html>.

tratamiento de agua tras su renuncia, y utilizó un acceso remoto no revocado para interrumpir los procesos de limpieza y desinfección.

Otro incidente ocurrió en el año 2000 en Queensland (Australia), cuando un excontratista insatisfecho llevó a cabo un ataque cibernético contra Maroochy Water Services.⁵⁵ El atacante utilizó sus conocimientos técnicos y acceso privilegiado para manipular el sistema SCADA de las estaciones de bombeo de aguas residuales, para liberar aproximadamente un millón de litros de aguas residuales sin tratar a lo largo del espacio público. Este incidente no solo causó un impacto ambiental significativo, como la contaminación de ríos y parques, sino que también afectó la vida marina y las actividades económicas locales.



¿Cuál es la funcionalidad de un sistema SCADA?

Un sistema SCADA (*supervisory control and data acquisition*) es una herramienta clave de la automatización industrial. Es un sistema informático que permite supervisar y controlar el funcionamiento de instalaciones remotas a través de la recopilación, transmisión y análisis de datos en tiempo real.

Estos incidentes evidencian que las buenas prácticas del sector TIC, como la limitación de privilegios o la revocación de accesos para los exempleados, deben ser especialmente implementadas en dicho ámbito. La falta de control en la gestión de accesos privilegiados puede dar como resultado sabotajes que conllevan consecuencias muy graves, tanto para el medioambiente como para la salud pública y la economía local. Por ello, es crucial que las entidades del sector del agua adopten medidas de seguridad robustas y aseguren que los accesos sean gestionados adecuadamente para prevenir este tipo de incidentes.

⁵⁵ Control Engineering, “Throwback Attack: An insider releases 265.000 gallons of sewage on the Maroochy Shire”, 2021, <https://www.controleng.com/throwback-attack-an-insider-releases-265000-gallons-of-sewage-on-the-maroochy-shire/>.

5.7. Recomendaciones



Es necesario que las organizaciones involucradas en el sector del agua:

- **Protejan** los dispositivos desplegados a lo largo del ciclo de vida del agua contra posibles ciberataques a través de medidas de seguridad adecuadas.
- **Incrementen** la inversión en la infraestructura del sector del agua y modernicen los sistemas utilizados para mejorar su eficiencia y seguridad.
- **Establezcan** reglas y procedimientos para asegurar que los sistemas de información estén siempre correctamente actualizados.
- **Realicen** un análisis de riesgos al implementar nuevas tecnologías para evaluar su posición frente a las amenazas que puedan surgir.
- **Implementen** mecanismos de control para garantizar que los datos recibidos durante el ciclo de vida del agua sean precisos y resistentes a fallos o alteraciones intencionadas.
- **Fomenten** la transmisión de información veraz y eviten bulos, dando visibilidad pública a los procesos de tratamiento del agua.
- **Aseguren** que sus proveedores sigan las mejores prácticas en materia de ciberseguridad, implantando las medidas necesarias para ello.



6. La amenaza a la confidencialidad de los datos en el sector del agua crece con la digitalización y su valor estratégico

La transformación digital del sector hídrico ha disparado significativamente la cantidad de datos gestionados y su confidencialidad. Las empresas del sector no solo recopilan información crítica para tareas como el monitoreo, el control de productos químicos y la automatización del ciclo del agua, sino que también tratan grandes volúmenes de datos personales de los clientes. Esta creciente generación de datos resulta un activo de gran valor, que atrae el interés de actores malintencionados hacia el sector del agua. Información sobre infraestructuras críticas, patrones de consumo y datos personales de los clientes pueden ser explotados para diversos fines, desde la difusión de fraudes hasta el sabotaje de operaciones.

Por un lado, los grupos de APT, respaldados por Estados rivales, pueden llevar a cabo acciones de ciberespionaje para obtener información estratégica y ventajas competitivas con relación a un sector tan estratégico como el hídrico. Por otro lado, los *hacktivistas*, impulsados por motivaciones ideológicas, pueden intentar comprometer datos con el objetivo de exponer prácticas que consideran injustas o inadecuadas, generar impacto mediático o presionar a las organizaciones para que cambien sus políticas.

También el cibercrimen dedicado al *ransomware* representa un desafío significativo, dado que es habitual que acompañen sus ciberataques con el robo masivo de datos personales, con la amenaza de publicarlos si no se efectúa un pago. A su vez, estos robos y filtraciones de datos personales desencadenan nuevas oleadas de ataques dirigidos a las personas afectadas, como campañas de *phishing*.

La ciberseguridad en el sector del agua se enfrenta a desafíos significativos debido a la combinación de tecnologías industriales heredadas con la creciente necesidad de conectividad. La falta de inversiones históricas y la reticencia a actualizar los sistemas por temor a interrupciones operativas han dejado muchas plantas de tratamiento de agua vulnerables a ciberataques. Un informe de la EPA de 2024 reveló que el 9 % de los sistemas públicos de agua potable tenían vulnerabilidades críticas, y que más del 70 % no cumplían con las evaluaciones de riesgos y planes de respuesta a emergencias requeridos por la ley. Este caso subraya la necesidad urgente de fomentar una cultura de actualizaciones y análisis de vulnerabilidades para proteger la información y prevenir ciberataques.

La digitalización y el uso de plataformas de pago electrónicas obligan al sector hídrico a manejar una cantidad creciente de datos personales de clientes, lo que aumenta la responsabilidad legal en términos de cumplimiento normativo. El incumplimiento de leyes como el RGPD y la LOPDGDD puede acarrear serias repercusiones legales, lo que subraya la necesidad de implementar medidas de seguridad robustas para proteger los datos delicados y mantener la confianza de los clientes.

Aspectos a tratar:

- ✓ La filtración de datos personales en el sector puede facilitar el fraude y el robo de identidad de sus clientes.
- ✓ Los consumidores están expuestos a ataques de suplantación de las entidades de suministro de agua con *phishings* y falsos técnicos.
- ✓ El *phishing* amenaza la seguridad y confidencialidad de los datos del sector del agua.
- ✓ La rivalidad entre economías incentiva el ciberespionaje industrial.
- ✓ La doble amenaza del *ransomware* no solo afecta la disponibilidad de los sistemas, sino que facilita el robo de datos personales.
- ✓ La reticencia a actualizar sistemas de información aumenta el robo de datos.
- ✓ Las regulaciones promueven la confidencialidad de los datos en el sector hídrico.

6.1. La filtración de datos personales en el sector puede facilitar el fraude y el robo de identidad de sus clientes

La transformación digital de los servicios de suministro básico ha impulsado una gestión más eficiente y precisa, pero también ha incrementado la recopilación y el procesamiento de grandes volúmenes de datos personales de los consumidores. En el sector del agua, en el que la cobertura de los operadores es prácticamente universal, las empresas gestionan información de casi todos los hogares dentro de su área de competencia, lo que puede suponer datos de miles de ciudadanos.

Dichos datos no se limitan a nombres y documentos de identificación, sino que también incluyen direcciones, correos electrónicos, números de teléfono, datos bancarios y patrones de consumo de agua. Dada la cantidad y el valor de estos datos personales

tratados por las entidades del sector del agua, se han convertido en un blanco atractivo para los ciberdelincuentes, ya que pueden comercializarse en el mercado negro de la *dark web* y ser utilizados para fraudes a gran escala, como usurpación de identidad o estafas financieras.

¿Qué es la *dark web*?

Parte de la web profunda alojada en redes cifradas, superpuestas en internet, que utilizan el anonimato para el intercambio de información. (Fuente: Termcat)

Cabe destacar que una filtración de esta información no solo pone en riesgo la privacidad de miles de usuarios, sino que también puede generar un grave daño reputacional para las empresas gestoras, que quedan expuestas a sanciones legales y a la pérdida de confianza de la ciudadanía en la seguridad y fiabilidad del servicio.

En 2019, tuvo lugar un caso de fuga masiva de datos personales de los clientes de varios servicios municipales de suministro de agua en Estados Unidos. Los ciberdelincuentes aprovecharon las vulnerabilidades existentes en Click2Gov, el sistema de pago en línea, para insertar un código malicioso que interceptaba los datos introducidos por los usuarios durante las transacciones. Los servicios de agua de varios gobiernos locales quedaron afectados: Indio (California),⁵⁶ Aurora (Colorado),⁵⁷ Waco, Fort Worth (Texas),⁵⁸ entre otras. En el caso del Fort Worth Water Department, más de 3000 clientes vieron comprometidos los datos de su tarjeta de crédito: nombre, dirección, tipo, número, fecha de caducidad y hasta el código de seguridad (CVV).⁵⁹ Después del incidente, a raíz del riesgo de fraudes, los clientes afectados fueron compensados con un año de monitorización de crédito gratuito.

Los datos robados por ciberdelincuentes son comercializados en el mercado negro de la *dark web*, donde pueden generar grandes ganancias. Los compradores, a menudo grupos especializados en delitos cibernéticos, los utilizan para organizar campañas de fraude organizadas y específicamente dirigidas a los afectados, como correos de *phishing* personalizados, esquemas de ingeniería social o intentos de robo de identidad, más allá del uso directo de los datos de tarjetas. En el caso de los datos sustraídos en el citado incidente de la plataforma de pagos Clic2Gov, se usaron para fraudes con tarjetas de

⁵⁶ Infowatch, "Another click2gov data breach hits indio", 2019, <https://infowatch.com/analytical-research/another-click2gov-data-breach-hits-indio-california>.

⁵⁷ The Daily Swig, "Colorado municipality falls victim to Click2Gov software breach", 2019, <https://portswigger.net/daily-swig/colorado-municipality-falls-victim-to-click2gov-software-breach>.

⁵⁸ Tripwire, "Waco water bill attack just the latest in a wave of Click2Gov breaches", 2019, <https://www.tripwire.com/state-of-security/waco-water-bill-attack-click2gov-breaches>.

⁵⁹ Fort Worth Star-Telegram, "About 3,000 Fort Worth water customers may have had info stolen in a data breach", 2019, <https://www.star-telegram.com/news/local/fort-worth/article238073889.html>.

crédito, como transacciones no autorizadas, dado que varios clientes experimentaron cargos fraudulentos en sus cuentas tras las brechas.⁶⁰

6.2. Los consumidores están expuestos a ataques de suplantación de las entidades de suministro de agua con *phishings* y falsos técnicos

El *phishing* es una técnica de fraude cibernético que utiliza la suplantación de servicios de confianza para engañar a las víctimas y obtener información confidencial o inducirlos a efectuar acciones perjudiciales. Un ejemplo destacado de *phishing* en el sector del agua potable es el que ocurrió recientemente, en 2024, en Maine (Estados Unidos), donde unos estafadores se hicieron pasar por el Programa de Agua Potable del CDC (Center for Disease Control) para engañar a los operadores hídricos de la región.⁶¹ En esta campaña, los correos electrónicos falsos solicitaban a los operadores de agua que hicieran clic en un enlace para “verificar o actualizar” su información, bajo la amenaza de revocar su licencia si no lo hacían. Los operadores eran dirigidos a un sitio web malicioso donde se les pedía que introdujeran datos confidenciales, como credenciales de inicio de sesión o información personal.



¿En qué consiste el *phishing*?

Ciberataque que utiliza correos electrónicos, mensajería de texto, llamadas telefónicas o cualquier otro tipo de medio de comunicación para engañar a las víctimas y obtener información confidencial.

Esta estrategia se ha vuelto cada vez más sofisticada, especialmente al dirigirse a sectores como las compañías de servicios básicos, que representan una oportunidad ideal para los atacantes. Dado que todos los ciudadanos son consumidores de estos servicios, como el suministro de agua, electricidad o gas, se convierten en víctimas potenciales. Los atacantes personalizan sus mensajes para que parezcan legítimos, aprovechando la confianza que las personas tienen en estas organizaciones y utilizando datos específicos —como nombres, cargos o detalles de la empresa— obtenidos de redes sociales, sitios web corporativos o filtraciones previas. Precisamente, en 2021, el Grupo Agbar alertó sobre una estafa por suplantación de identidad en la que ciberdelincuentes contactaban con los clientes por correo electrónico o teléfono,

⁶⁰ Flashpoint, “Click2Gov or Click2Breach? What We Know About the Click2Gov Breach”, 2018, <https://flashpoint.io/blog/click2gov-or-click2breach-what-we-know-about-the-click2gov-breach/>.

⁶¹ Water ISAC, “Threat Advisory – Phishing Campaign Impersonates State CDC Drinking Water Program”, 2024, https://www.waterisac.org/portal/threat-advisory—phishing-campaign-impersonates-state-cdc-drinking-water-program_.

haciéndose pasar por empleados y solicitando que usaran un nuevo número de cuenta para los pagos.⁶²

Esta suplantación puede no limitarse al mundo digital y extenderse al mundo físico, hasta el punto de que la suplantación de trabajadores de servicios públicos es otro ataque preocupante que expone a los consumidores. Los estafadores se hacen pasar por técnicos de servicios como el agua para entrar en viviendas y robar o recopilar datos. Afecta a casi todos, por ser usuarios de estos servicios conocidos, y las filtraciones de datos ayudan a personalizar las estafas, lo que las hace más creíbles.

En este sentido, recientemente, Aigües de l'Horta⁶³ y Aigües d'Elx⁶⁴ han alertado sobre intentos de fraude en los que impostores, haciéndose pasar por operarios, intentan acceder a viviendas con excusas como revisiones de calderas o controles de agua, y luego cobran por servicios falsos. Ambas compañías recuerdan que su personal solo entra en domicilios si el cliente lo solicita oficialmente y nunca cobra por estos servicios. Además, los operarios legítimos llevan identificación verificable, y los análisis en el grifo del consumidor son gratuitos.

Teniendo en cuenta este escenario, es importante que las autoridades impulsen la protección de los datos personales en los servicios hídricos y que actúen con rapidez ante cualquier intento de fraude o campaña de *phishing*, alertando a la ciudadanía para minimizar riesgos. Por su parte, los ciudadanos deben mantenerse atentos; verificar siempre la identidad de correos electrónicos, llamadas telefónicas o supuestos operarios que intenten acceder a su hogar, y evitar compartir información confidencial o realizar pagos no autorizados. La prevención y la información son clave para reforzar la seguridad.

6.3. También en el sector del agua, el *phishing* supone una auténtica amenaza a la seguridad y confidencialidad de los datos

El robo de credenciales mediante ingeniería social en el sector del agua representa un grave riesgo para la privacidad y seguridad de los datos. Una fuga de datos, ya sea por exposición involuntaria o ciberataque, puede facilitar a un cibercriminal la obtención de información para llevar a cabo ataques de *phishing* convincentes. Estos delincuentes pueden hacerse pasar por servicios o compañeros internos a la misma organización, proveedores o entidades del sector hídrico. La preocupación por el *phishing* en este

⁶² SomMollet, "Agbar alerta d'una possible ciberestafa relacionada amb el servei d'aigua", 2021, <https://www.sommollet.cat/noticia/75711/agbar-alerta-duna-possible-ciberestafa-relacionada-amb-el-servei-daigua>.

⁶³ Aigües de l'Horta, "Alerta sobre un fraude de suplantación y cobros en metálico", 2020, <https://www.aigueshorta.es/va/-/alerta-sobre-un-fraude-de-suplantacion-y-cobros-en-metalico>.

⁶⁴ Aigües d'Elx, "Alerta sobre un fraude de suplantación para acceder al interior de las viviendas", 2020, <https://www.aigueselx.com/-/alerta-sobre-un-fraude-de-suplantacion-para-acceder-al-interior-de-las-viviendas>.

sector no es infundada, ya que, según encuestas realizadas por Fortinet⁶⁵ acerca de los ciberataques que más preocupan dentro del sector hídrico, el 63 % de los encuestados consideran que el *malware/phishing* es la segunda tipología de ataque que más preocupa en el sector, solo por detrás del *ransomware*, con un 65 %.

En este contexto, los atacantes diseñan correos electrónicos que aparentan ser legítimos, en los que incorporan detalles personales del destinatario, como su nombre o información de su cuenta de servicio. Esta personalización puede ser el resultado de filtraciones de datos previas, y que los ciberdelincuentes hayan obtenido información delicada vendida en la *dark web* para realizar el ataque. Además, los atacantes pueden llevar a cabo investigaciones sobre la organización o sus miembros, utilizando herramientas de reconocimiento y explorando fuentes públicas, como internet y redes sociales. Estos métodos permiten al atacante crear un correo con una apariencia auténtica, lo que incrementa la probabilidad de que el destinatario confíe en el mensaje. Un ejemplo de este engaño podría ser un correo que finge ser una notificación sobre un error de facturación, solicitando al usuario que haga clic en un enlace o proporcione información adicional. Además, hasta podría incluir un archivo adjunto, supuestamente con la “nueva factura”, que en realidad contiene *malware*.

Para prevenir las consecuencias del *phishing*, es fundamental mantenerse informado sobre las tácticas comunes y que las entidades organicen programas de concienciación sobre ciberseguridad y, en especial, sobre los ataques de *phishing*. Dichos ataques se pueden identificar porque los mensajes tienen en común que generan un sentido de urgencia para conseguir algún tipo de interacción del usuario, ya sea introduciendo los datos o abriendo un fichero. Además, tradicionalmente, presentaban errores gramaticales y provenían de remitentes desconocidos, quizás mediante direcciones que parecían legítimas. Sin embargo, hoy en día, gracias a las filtraciones de datos y al mercado negro de credenciales robadas, los cibercriminales consiguen comprometer cuentas de correo electrónico legítimas. Y, gracias al uso de IA generativas, los cibercriminales pueden elaborar textos convincentes, bien escritos y sin errores.

Sin duda, la identificación del *phishing* es una tarea cada vez más compleja, de modo que también es recomendable habilitar la autenticación de doble factor y mantener el *software* de seguridad actualizado. Además, siempre se debe verificar la autenticidad de los correos, enlaces y archivos adjuntos.

6.4. El enfrentamiento económico y estratégico entre países rivales incentiva el ciberespionaje industrial en el sector del agua

La información que trata el sector del agua tiene un alto valor estratégico. Como servicio esencial, los sistemas hídricos son fundamentales para la estabilidad de un país, y su alteración podría generar caos o afectar la seguridad nacional. Los actores estatales

⁶⁵ Fortinet, “2024 Cybersecurity in Water Management Facilities Report”, 2024, <https://www.fortinet.com/content/dam/fortinet/assets/reports/report-cybersecurity-in-water-management-facilities.pdf>.

pueden buscar acceso a estos sistemas para recopilar datos sobre la red de distribución, estudiar vulnerabilidades que permitan sabotajes en el futuro o incluso comprometer la calidad del agua como una forma de guerra híbrida.

Por todo ello, los datos del sector hídrico atraen el interés de quienes buscan robarlos para obtener beneficios, ya sean económicos o estratégicos. Detrás de estas acciones se encuentran los grupos de APT, cuyo objetivo es obtener información estratégica que proporcione ventajas competitivas sobre economías o países rivales. Los Estados patrocinadores buscan obtener ventajas estratégicas sobre sus adversarios, utilizando el ciberespionaje como una herramienta clave en sus estrategias geopolíticas. Esta actividad está en aumento y se encuentra estrechamente vinculada a las tensiones geopolíticas.

Un ejemplo destacable de esta actividad es la campaña china conocida como Volt Typhoon,⁶⁶ llevada a cabo por el grupo de APT Vanguard Panda en marzo de 2024. Esta campaña llamó la atención cuando Microsoft detectó actividad cibernética en Guam, una ubicación clave en la defensa de Taiwán. Los atacantes lograron infiltrarse en múltiples redes críticas que gestionan las comunicaciones, la energía y el suministro de agua en bases militares estadounidenses, tanto en el país como en el extranjero. Su acceso fue profundo y sostenido, lo que les permitió robar información valiosa. El alcance completo de esta infiltración se reveló meses después, cuando se informó de que formaba parte de un ataque de gran envergadura. Además, algunas investigaciones posteriores sugieren que los ciberataques del tipo de Volt Typhoon, aparte del robo de información estratégica, también buscan posicionarse para posibles sabotajes futuros, especialmente en potenciales contextos de conflicto militar.

Sin embargo, no solo los actores estatales están interesados en los datos del sector hídrico, dado que también podrían ser objeto de ataques por parte de grupos *hacktivistas* que actúan por razones ideológicas o políticas. Estos grupos pueden desear robar y exponer públicamente información, motivados por preocupaciones medioambientales, como el impacto negativo del tratamiento del agua en la salud o el medioambiente. Asimismo, podrían protestar contra abusos políticos, corrupción o falta de transparencia en la gestión de los recursos hídricos. En estos casos, los *hacktivistas* buscan generar conciencia o presionar para un cambio mediante la interrupción o exposición de las prácticas de las entidades involucradas en el sector del agua.

6.5. *Ransomware* con doble extorsión: afecta la disponibilidad de un servicio esencial y el robo de los datos personales de clientes

Tal y como se ha destacado previamente, el sector del agua, como servicio esencial, se enfrenta a la amenaza del *ransomware*. Sin embargo, el impacto de un ataque de *ransomware* no se limita solo a la disponibilidad, ya que cada vez es más común que los

⁶⁶ Dark Reading, “China’s Volt Typhoon APT Burrows Deeper Into US Critical Infrastructure”, 2023, <https://www.darkreading.com/vulnerabilities-threats/china-s-volt-typhoon-apt-burrows-us-critical-infrastructure>.

cibercriminales utilicen el secuestro de datos como una herramienta adicional de extorsión, ofreciendo a sus víctimas la posibilidad de evitar la filtración de información delicada mediante el pago de un rescate. Esta forma de ataque, llamada “ataque de doble extorsión”, es cada vez más habitual. En el año 2021, ThreatLabz⁶⁷ identificó que



19 grupos de *ransomware* estaban utilizando tácticas de doble o múltiple extorsión en sus ciberataques. Desde entonces, este número se ha incrementado hasta alcanzar las 44 familias en el estudio más reciente, de 2024. De hecho, es una técnica tan efectiva que en algunos casos la extorsión a la víctima se basa exclusivamente en el robo de datos y la amenaza de publicarlos, sin cifrado de datos. Recibe el nombre de *extortion-only ransomware* y permite a los actores maliciosos obtener beneficios más rápidamente, ya que eliminan la necesidad de desarrollar y mantener *software* de cifrado y descifrado. Además, estos ataques son más difíciles de detectar y reciben menos atención de las autoridades, dado que no interrumpen las operaciones críticas.

¿Cómo funciona el *extortion-only ransomware*?

Los ataques de *extortion-only ransomware* omiten el proceso de cifrado y se centran exclusivamente en la amenaza de exponer los datos sustraídos si no se efectúa el pago.

Un ejemplo lo tenemos en la empresa Southern Water (Reino Unido),⁶⁸ que presta servicios a millones de clientes en el sur de Inglaterra, la cual fue víctima de un ataque por parte del grupo cibercriminal de *ransomware* Black Basta a principios de 2024. A pesar de que los servicios de agua y aguas residuales no se vieron afectados, los atacantes robaron 750 GB de datos, entre los cuales se encontraban documentos de identidad, información personal de empleados y clientes, y documentos corporativos. Posteriormente, Southern Water confirmó que entre el 5 % y el 10 % de los datos de sus clientes habían sido robados y potencialmente vendidos en la *dark web*. Obviamente, Black Basta amenazó con divulgar los datos robados si no se pagaba un rescate.⁶⁹

⁶⁷ Zscaler, “El Informe sobre Ransomware 2023 de Zscaler arroja un crecimiento en ataques de ransomware a nivel mundial de casi 40 %”, 2023, <https://www.zscaler.com/es/press/zscalers-ransomware-report-2023-shows-global-ransomware-attack-growth-of-nearly-40-percent>.

⁶⁸ The Register, “UK water giant admits attackers broke into system as gang holds it to ransom”, 2024, https://www.theregister.com/2024/01/23/southern_water_confirms_cyberattack/.

⁶⁹ Security Matters, “Customer and employee data at risk in wake of cyber attack on Southern Water”, 2024, <https://securitymattersmagazine.com/customer-and-employee-data-at-risk-in-wake-of-cyber-attack-on-southern-water>.

6.6. Hace falta una cultura de actualizaciones y análisis de vulnerabilidades para proteger la información

A pesar de que, recientemente, la ciberseguridad se ha convertido en una preocupación crítica en el sector del agua, como se ha detallado previamente, la histórica falta de inversiones ha dado lugar a entornos que combinan tecnologías industriales heredadas (*legacy*) con crecientes necesidades de conectividad, lo que los expone a amenazas procedentes de internet. Además, en entornos críticos industriales, como pueden ser las plantas de tratamiento del agua, persiste una reticencia a actualizar los sistemas, debido a que dichas actualizaciones pueden generar caídas de servicio y otros problemas operativos. Esto se puede constatar en plantas industriales que dependen de tecnología antigua, como Windows XP, que ya no recibe parches de seguridad.

Así lo confirmó un informe de 2024 de la EPA (Environmental Protection Agency), Estados Unidos, que constató que el 9 % de los sistemas públicos de agua potable tenían vulnerabilidades críticas o de alta prioridad en ciberseguridad. También afirmó que más del 70 % de los sistemas de agua no cumplían una disposición de una ley de 2018 que requiere desarrollar o actualizar evaluaciones de riesgos y planes de respuesta a emergencias. Sin embargo, también señaló que los hallazgos no fueron sorprendentes, dado que la mayoría de los miles de instalaciones de agua del país carecen de fondos o experiencia para implementar estándares de ciberseguridad en su tecnología.

En el sector del agua, la cultura de ciberseguridad todavía tiene poco recorrido y es limitada, lo que incrementa la existencia de riesgos. Es fundamental que el sector reconozca la importancia de analizar y corregir estas debilidades para evitar ciberataques que puedan exponer datos confidenciales. La identificación de fallos permite detectarlos antes de que sean explotados, lo que asegura que las organizaciones tomen medidas preventivas.

No lo hizo así el Departamento de Agua y Energía de Los Ángeles (DWP),⁷⁰ que fue acusado de ocultar importantes brechas de ciberseguridad a los reguladores, a pesar de que sus directivos eran plenamente conscientes de dichas vulnerabilidades. Ardent Cyber Solutions LLC, la empresa contratada para la evaluación de ciberseguridad del DWP, descubrió un elevado número de vulnerabilidades en la red sin parchear, que fueron comunicadas a los altos ejecutivos y al presidente de la junta en agosto de 2019. Sin embargo, en lugar de abordar estos problemas, los directivos y funcionarios de la ciudad hicieron declaraciones falsas y ocultaron hechos cruciales para encubrir las deficiencias de seguridad.⁷¹

⁷⁰ Infosecurity Magazine, “Los Angeles Utility Accused of Cybersecurity Coverup”, 2020, <https://www.infosecurity-magazine.com/news/la-utility-accused-of/>.

⁷¹ Statescoop, “‘Critical’ cyber vulnerabilities found in many water utilities, warns EPA inspector general”, 2024, <https://statescoop.com/epa-critical-cybersecurity-vulnerabilities-water-utilities-2024/>.

6.7. El marco regulador impone medidas estrictas para proteger los datos personales de los usuarios

En el mundo digital, donde la información es un activo crítico, la seguridad y confidencialidad de los datos se ha convertido en una prioridad para todos los sectores. Las regulaciones desempeñan un papel crucial al establecer marcos normativos que garantizan la protección de los datos frente a amenazas e imponen sanciones a aquellas empresas u organizaciones que no los cumplan.

A nivel europeo, el Reglamento General de Protección de Datos (RGPD)⁷² establece estándares para la protección de datos personales y es aplicable a cualquier organización que maneje dichos datos dentro de la Unión Europea. En España, el RGPD se transpuso a través de la Ley Orgánica de Protección de Datos y Garantía de los Derechos Digitales (LOPDGDD),⁷³ que adapta y complementa las disposiciones del Reglamento europeo. Estas normativas afectan a todas las entidades públicas y privadas que procesan datos personales, incluyendo las del sector hídrico, y aseguran que los datos se gestionen de modo seguro y respetuoso con los derechos de los individuos. El incumplimiento puede acarrear severas sanciones, con multas que llegan a los 20 millones de euros o el 4 % de la facturación global anual de la entidad, además de dañar su reputación y sus relaciones comerciales.

La aplicación de estas regulaciones es muy relevante en el sector hídrico, dada la amplia base de clientes que maneja. Esto supone la gestión de miles de registros con nombres, números de identificación, correos electrónicos, números de teléfono, información bancaria, detalles de facturación, etc. Además, también procesan datos de sus propios trabajadores. En conjunto, estos datos son un objetivo atractivo para los ciberdelincuentes, lo que subraya la necesidad de implementar medidas de seguridad robustas para proteger la privacidad y la integridad de la información.

Además de cumplir con el RGPD, las organizaciones pueden fortalecer aún más su seguridad de la información adoptando estándares internacionales reconocidos. En este sentido, la ISO/IEC 27001⁷⁴ es el estándar de referencia para la gestión de la seguridad de la información. Esta norma se aplica a cualquier organización que desee proteger sus activos de información, estableciendo un sistema de gestión que identifica y mitiga riesgos. La norma ISO/IEC 27001 es certificable de forma voluntaria, y supone una práctica positiva para garantizar que se cumplen los estándares de seguridad, así como para ganarse una buena reputación de la organización y la confianza de los consumidores.

⁷² Unión Europea, Reglamento General de Protección de Datos, 2018, <https://eur-lex.europa.eu/ES/legal-content/summary/general-data-protection-regulation-gdpr.html>.

⁷³ BOE, Ley Orgánica 3/2018, de 5 de diciembre, de Protección de Datos y Garantía de los Derechos Digitales, <https://www.boe.es/boe/dias/2018/12/06/pdfs/BOE-A-2018-16673.pdf>.

⁷⁴ ISO 27001, Norma ISO 27001, 2022, <https://www.normaiso27001.es/>.

6.8. Recomendaciones



Es necesario que las organizaciones involucradas en el sector del agua:

- **Realicen** campañas de sensibilización y concienciación para todos los empleados sobre las mejores prácticas en ciberseguridad, como la gestión de contraseñas seguras y la identificación de ataques de ingeniería social.
- **Instruyan** a los usuarios de las organizaciones del sector del agua para que validen la autenticidad de las direcciones de correo electrónico sospechosas, consulten directamente al remitente por otro medio o contacten con el servicio técnico.
- **Aseguren** que los usuarios no revelen sus credenciales a terceros, ya sea de forma escrita (en caso de *phishing*) o de forma oral (en caso de *vishing*).
- **Proporcionen** formación adecuada contra el fraude, especialmente dirigida a responsables de finanzas y aprovisionamiento.
- **Protejan** los datos personales con medidas adecuadas, como cortafuegos y controles de acceso con doble factor de autenticación, y aseguren su almacenamiento mediante cifrado seguro para evitar que un intruso pueda robarlos en texto plano.